

**SUPSI**

# Rilevamento dati personali in documenti non strutturati aziendali

---

Studente/i

**Algisi Gabriele**

Relatore

**Gay Mario**

---

Correlatore

**Consoli Angelo**

---

Committente

**Gay Mario**

---

Corso di laurea

**Ingegneria Informatica**

Modulo

**C11303**

---

Anno

**2025-2026**

---

Data

**15 luglio 2026**

STUDENTSUPSI



# Indice

|          |                                                                                      |          |
|----------|--------------------------------------------------------------------------------------|----------|
| <b>1</b> | <b>Introduzione</b>                                                                  | <b>1</b> |
| 1.1      | Riassunto / Abstract . . . . .                                                       | 1        |
| 1.2      | Progetto assegnato . . . . .                                                         | 1        |
| 1.3      | Contesto . . . . .                                                                   | 2        |
| 1.4      | Motivazione . . . . .                                                                | 3        |
| 1.5      | Obiettivi del progetto . . . . .                                                     | 3        |
| <b>2</b> | <b>Analisi dei requisiti</b>                                                         | <b>5</b> |
| 2.1      | Requisiti funzionali . . . . .                                                       | 5        |
| 2.1.1    | Acquisizione dell'input . . . . .                                                    | 5        |
| 2.1.2    | Estrazione del testo . . . . .                                                       | 5        |
| 2.1.3    | Rilevamento delle PII . . . . .                                                      | 5        |
| 2.1.4    | Aggregazione delle PII frammentate   DA VALUTARE . . . . .                           | 6        |
| 2.1.5    | Costruzione di una knowledge base delle entità   DA VALUTARE . . . . .               | 6        |
| 2.1.6    | Ingestione del/i ROPA . . . . .                                                      | 6        |
| 2.1.7    | Confronto dei risultati di analisi con il ROPA . . . . .                             | 7        |
| 2.1.8    | Rilevamento delle anomalie di conformità . . . . .                                   | 7        |
| 2.1.9    | Generazione report per DPO . . . . .                                                 | 7        |
| 2.1.10   | Persistenza e aggiornamento del registro delle PII rilevate . . . . .                | 7        |
| 2.1.11   | Feedback loop . . . . .                                                              | 8        |
| 2.1.12   | Analisi contestuale della struttura del filesystem . . . . .                         | 8        |
| 2.1.13   | Impieghi selettivi dell'AI generativa . . . . .                                      | 8        |
| 2.2      | Requisiti normativi . . . . .                                                        | 9        |
| 2.2.1    | Conformità ai principi di limitazione delle finalità e della conservazione . . . . . | 9        |
| 2.2.2    | Riferimento al registro delle attività di trattamento come fonte normativa . . . . . | 10       |
| 2.2.3    | Copertura delle categorie di dati degni di particolare attenzione . . . . .          | 10       |
| 2.2.4    | Posizionamento rispetto all'art. 32(1)(d) GDPR . . . . .                             | 10       |
| 2.2.5    | Esclusione delle basi giuridiche dal perimetro di analisi automatica . . . . .       | 11       |
| 2.3      | Requisiti operativi . . . . .                                                        | 11       |
| 2.3.1    | Elaborazione locale dei dati . . . . .                                               | 11       |

|          |                                                                                                   |           |
|----------|---------------------------------------------------------------------------------------------------|-----------|
| 2.3.2    | Vincolo sui modelli AI impiegabili . . . . .                                                      | 12        |
| 2.3.3    | Facilità di installazione e aggiornamento . . . . .                                               | 13        |
| 2.3.4    | Estensibilità delle categorie e dei detector . . . . .                                            | 13        |
| 2.3.5    | Minimizzazione dei dati trattati dal sistema stesso . . . . .                                     | 14        |
| 2.3.6    | Operatività senza addestramento iniziale (zero-training) . . . . .                                | 14        |
| 2.4      | Requisiti di qualità . . . . .                                                                    | 15        |
| 2.4.1    | Prestazioni su larga scala . . . . .                                                              | 15        |
| 2.4.2    | Precisione del rilevamento . . . . .                                                              | 15        |
| 2.4.3    | Tracciabilità delle anomalie . . . . .                                                            | 15        |
| 2.5      | Requisiti di interfaccia . . . . .                                                                | 16        |
| 2.5.1    | Interfaccia a riga di comando (CLI) . . . . .                                                     | 16        |
| 2.5.2    | Formato di output del report . . . . .                                                            | 16        |
| <b>3</b> | <b>Stato dell'arte</b>                                                                            | <b>17</b> |
| 3.1      | Background tecnologico . . . . .                                                                  | 17        |
| 3.1.1    | Spiegazione supervised vs unsupervised . . . . .                                                  | 17        |
| 3.1.2    | Pre-tuning vs fine-tuning . . . . .                                                               | 18        |
| 3.1.3    | Spiegazione zero-shot learning . . . . .                                                          | 18        |
| 3.2      | Definizione e inquadramento del problema: Dalla Data Anonymization alla Data Governance . . . . . | 19        |
| 3.3      | Compliance checking automatizzato . . . . .                                                       | 19        |
| 3.4      | Approcci tecnici di PII detection . . . . .                                                       | 19        |
| 3.4.1    | Recognition rule-based . . . . .                                                                  | 19        |
| 3.4.2    | Recognition con NLP - NER . . . . .                                                               | 20        |
| 3.4.3    | Recognition con AI generativa . . . . .                                                           | 20        |
| 3.4.4    | Limitazioni nella soluzione . . . . .                                                             | 20        |
| 3.4.5    | Soluzioni ibride . . . . .                                                                        | 21        |
| 3.4.6    | Confronto empirico degli approcci . . . . .                                                       | 21        |
| 3.4.6.1  | Prestazioni dei sistemi rule-based . . . . .                                                      | 21        |
| 3.4.6.2  | Prestazioni dei modelli NER supervisionati . . . . .                                              | 21        |
| 3.4.6.3  | Prestazioni dei modelli NER zero-shot . . . . .                                                   | 22        |
| 3.4.6.4  | Prestazioni dell'AI generativa . . . . .                                                          | 22        |
| 3.4.6.5  | Convergenza verso la pipeline ibrida . . . . .                                                    | 22        |
| 3.4.6.6  | Matrice di confronto sintetica . . . . .                                                          | 23        |
| 3.5      | Analisi del training . . . . .                                                                    | 23        |
| 3.5.1    | Pre-training e fine-tuning (Paradigma classico) . . . . .                                         | 23        |
| 3.5.2    | Span-matching e Zero-shot (Il paradigma GLiNER) . . . . .                                         | 24        |
| 3.6      | Sfide nell'elaborazione documentale . . . . .                                                     | 24        |
| 3.6.1    | Docling . . . . .                                                                                 | 24        |

|           |                                                                 |           |
|-----------|-----------------------------------------------------------------|-----------|
| 3.6.2     | Altro...                                                        | 24        |
| 3.7       | Panoramica dei sistemi esistenti                                | 25        |
| 3.7.1     | Sistemi open-source                                             | 25        |
| 3.7.2     | Sistemi commerciali                                             | 25        |
| 3.8       | Sintesi del gap e posizionamento del progetto                   | 26        |
| <b>4</b>  | <b>Analisi dei rischi</b>                                       | <b>29</b> |
| 4.1       | Rischi di progetto                                              | 30        |
| 4.1.1     | Disponibilità e qualità dei dataset di valutazione              | 30        |
| 4.1.2     | Complessità dell'integrazione multi-approccio                   | 30        |
| 4.1.3     | Costo computazionale e tempi di elaborazione                    | 30        |
| 4.1.4     | Dipendenza da modelli e librerie di terze parti                 | 30        |
| 4.1.5     | Carenza di competenze specialistiche                            | 30        |
| 4.1.6     | Scope creep e requisiti in evoluzione                           | 30        |
| 4.2       | Rischi di prodotto                                              | 30        |
| 4.2.1     | Accuratezza insufficiente nella detection delle PII             | 30        |
| 4.2.2     | Falsi positivi e impatto sull'usabilità                         | 30        |
| 4.2.3     | Falsi negativi e mancata rilevazione di PII critiche            | 30        |
| 4.2.4     | Generalizzazione cross-domain (domain-silo problem)             | 30        |
| 4.2.5     | Supporto multilingue e multilocalizzazione                      | 30        |
| 4.2.6     | Scalabilità su filesystem di grandi dimensioni                  | 30        |
| 4.2.7     | Qualità e completezza dei ROPA in input                         | 30        |
| 4.2.8     | Conformità normativa e aggiornamento dei framework legali       | 30        |
| 4.2.9     | Sicurezza e protezione dei dati durante l'analisi               | 30        |
| 4.3       | Valutazione dei rischi                                          | 30        |
| 4.3.1     | Criteri di classificazione                                      | 30        |
| 4.3.2     | Matrice probabilità–impatto                                     | 30        |
| 4.4       | Strategie di mitigazione                                        | 30        |
| <b>5</b>  | <b>Architettura del sistema</b>                                 | <b>31</b> |
| 5.1       | Ingestione e modello dati del ROPA                              | 35        |
| 5.1.1     | Strutturazione a monte o delega all'AI                          | 35        |
| 5.1.2     | Il registro-tipo CNIL come schema di riferimento                | 35        |
| 5.1.3     | Normalizzazione in un modello relazionale                       | 36        |
| 5.1.4     | Ruolo circoscritto dell'AI: normalizzazione, non strutturazione | 36        |
| 5.1.5     | Punti aperti di progettazione                                   | 37        |
| 5.1.5.0.1 | Granularità della corrispondenza categorie–PII.                 | 37        |
| 5.1.5.0.2 | Allineamento nLPD–GDPR.                                         | 37        |
| 5.1.5.0.3 | ROPA non strutturato.                                           | 37        |
| 5.2       | Persistenza del registro delle PII                              | 37        |

|           |                                                                                        |           |
|-----------|----------------------------------------------------------------------------------------|-----------|
| 5.2.1     | Il requisito di tracciamento temporale . . . . .                                       | 38        |
| 5.2.2     | Approcci valutati . . . . .                                                            | 38        |
| 5.2.2.1   | Opzione A — Snapshot completi . . . . .                                                | 38        |
| 5.2.2.2   | Opzione B — Event sourcing puro . . . . .                                              | 38        |
| 5.2.2.3   | Opzione C — Changelog ibrido delta-based . . . . .                                     | 39        |
| 5.2.3     | Motivazione della scelta . . . . .                                                     | 40        |
| 5.2.4     | Modello dati concettuale . . . . .                                                     | 40        |
| 5.2.5     | Punti aperti di progettazione . . . . .                                                | 41        |
| 5.2.5.0.1 | Registrazione della «scomparsa» di una PII: esplicita<br>o implicita? . . . . .        | 41        |
| 5.2.5.0.2 | Significato dell'evento «modifica». . . . .                                            | 41        |
| 5.2.5.0.3 | Vocabolario chiuso dei tipi di variazione. . . . .                                     | 41        |
| 5.2.5.0.4 | Ambito dello snapshot iniziale. . . . .                                                | 42        |
| <b>6</b>  | <b>Implementazione</b>                                                                 | <b>43</b> |
| 6.1       | Tecnologia di persistenza del registro PII . . . . .                                   | 43        |
| 6.2       | Riuso di un motore di detection esistente: valutazione di Microsoft Presidio . . . . . | 43        |
| 6.2.0.0.1 | Profilo hardware. . . . .                                                              | 44        |
| <b>7</b>  | <b>Test e validazione</b>                                                              | <b>45</b> |
| <b>8</b>  | <b>Risultati e discussione</b>                                                         | <b>47</b> |
| <b>9</b>  | <b>Sviluppi futuri</b>                                                                 | <b>49</b> |
| <b>10</b> | <b>Studi effettuati</b>                                                                | <b>51</b> |
| 10.1      | Uso AI in rapporto al suo impatto ambientale . . . . .                                 | 51        |
| 10.2      | Considerazioni su training . . . . .                                                   | 51        |

# Capitolo 1

## Introduzione

### 1.1 Riassunto / Abstract

Qui ci sarà l'abstract...

### 1.2 Progetto assegnato

Le aziende e le organizzazioni soggette alla nLPD (nuova Legge federale sulla protezione dei dati) sono tenute a sapere dove si trovano i dati personali che trattano, a quale trattamento riportato del registro dei trattamenti sono riconducibili e se sono ancora entro i termini di conservazione dichiarati nel registro. Nella pratica però, gran parte di questi dati è dispersa in documenti non strutturati — ad esempio PDF, Word, Excel, scansioni — senza che l'organizzazione ne abbia visibilità sistematica.

Gli strumenti disponibili sul mercato, sia quelli più abordabili (es. PII Crawler, PII Tools) sia quelli enterprise (es. BigID, Varonis), sono progettati per garantire la conformità con normative europee (GDPR) o statunitensi (es.: CCPA) e non necessariamente gestiscono le categorie di dati specifiche della nLPD svizzera senza configurazioni e validazioni specifiche. Oltre a ciò, solo alcuni prodotti enterprise più avanzati integrano il registro dei trattamenti come input normativo configurabile. Di conseguenza la verifica del superamento del periodo di retention è spesso possibile solo tramite una categorizzazione molto precisa all'origine.

Il progetto propone lo sviluppo di un sistema in grado di evidenziare il divario tra le attività di trattamento dichiarate nel registro e l'effettiva gestione dei documenti aziendali, anche utilizzando tecniche NLP e AI. Per ciascun documento analizzato, il sistema deve identificare eventuali dati personali presenti (Personally Identifiable Information, PII), associare il documento alla corrispondente attività di trattamento combinando diversi indicatori (es. posizione nel file system, contenuto, PII identificati) e verificare la conformità al periodo di conservazione dichiarato nel registro. I documenti che hanno superato il loro periodo

di conservazione e le PII [1] che non possono essere collegate ad alcuna operazione di trattamento registrata devono essere segnalati come anomalie.

### 1.3 Contesto

La protezione dei dati personali costituisce oggi uno dei nodi centrali della governance organizzativa, tanto sul piano giuridico quanto su quello operativo. In Europa, il regolamento (UE) 2016/679 (GDPR) [2] ha introdotto un corpus di obblighi sostanziali per i titolari del trattamento, tra cui il principio di limitazione della conservazione sancito dall'art. 5(1)(e), secondo cui i dati personali devono essere conservati "in una forma che consenta l'identificazione degli interessati per un arco di tempo non superiore al conseguimento delle finalità per le quali sono trattati". In Svizzera, la nuova Legge federale sulla protezione dei dati (nLPD, RS 235.1, in vigore dal 1° settembre 2023) ha recepito principi analoghi: l'art 6(4) dispone che "i dati personali sono distrutti o resi anonimi appena non sono più necessari per lo scopo del trattamento", stabilendo un legame diretto tra la finalità dichiarata e il ciclo di vita del dato. Entrambe le normative impongono inoltre la tenuta di un registro delle attività di trattamento (ROPA, Record of Processing Activities). Il GDPR, all'art. 30(1)(f), richiede che il registro contenga, "ove possibile, i termini ultimi previsti per la cancellazione delle diverse categorie di dati"; la nLPD [3], all'art. 12(2)(e), prevede analogamente l'indicazione della durata di conservazione dei dati personali o dei criteri per determinarne la durata. Il ROPA costituisce dunque il documento normativo di riferimento per qualsiasi verifica di conformità: è in esso che l'organizzazione dichiara cosa tratta, perché, con quale base giuridica e per quanto tempo.

I due ordinamenti divergono tuttavia su un punto strutturalmente rilevante per qualsiasi sistema di verifica automatica. Il GDPR enumera positivamente le basi giuridiche lecite all'art. 6(1), subordinando la liceità del trattamento alla sussistenza di almeno una di esse. La nLPD adotta invece un approccio invertito: il trattamento è lecito per default in quanto esercizio della libertà d'azione dei privati, ma diventa illecito se lede ingiustificatamente la personalità dell'interessato ai sensi dell'art. 30. La giustificazione può provenire dal consenso, da un interesse preponderante o dalla legge, secondo il catalogo dell'art. 31. Questa differenza strutturale impone che un sistema di analisi della conformità tenga conto del framework giuridico applicabile, poiché il criterio con cui si valuta l'esistenza di una base legittima non è identico nei due contesti.

Nella pratica organizzativa, la conformità dichiarata nel registro tende a divergere dalla situazione reale dei dati. Gran parte dell'informazione trattata da un'organizzazione è incorporata in documenti non strutturati (file PDF, Word, Excel, messaggi di posta elettronica...) distribuiti su file system locali, server condivisi e servizi cloud. Questi documenti non recano metadati normalizzati che consentono di associarli automaticamente a un'attività di trattamento specifica, né di verificarne la conformità al periodo di retention dichiarato. Il risultato è



un divario strutturale tra ciò che il registro descrive e ciò che esiste effettivamente nei sistemi informativi dell'organizzazione.

Questo divario assume rilevanza giuridica diretta. Il GDPR all'art. 32(1)(d) qualifica come misura di sicurezza obbligatoria una procedura per testare, verificare e valutare regolarmente l'efficacia delle misure tecniche e organizzative al fine di garantire la sicurezza del trattamento. La nLPD, pur con formulazione più sintetica, impone all'art. 8(1) che il titolare e il responsabile del trattamento garantiscano, mediante appropriati provvedimenti tecnici e organizzativi, che la sicurezza dei dati personali sia adeguata al rischio. Un sistema in grado di rilevare automaticamente i dati personali presenti nei documenti aziendali e di verificarne la coerenza con il registro può essere inteso come implementazione tecnica di quest'obbligo.

## 1.4 Motivazione

Il divario descritto nella sezione precedente tra le attività di trattamento dichiarate nel registro e la gestione effettiva dei documenti non è soltanto un problema teorico: ha conseguenze dirette sulla capacità di un'organizzazione di dimostrare conformità. Un Data Protection Officer che debba rispondere a una richiesta dell'autorità di controllo, o semplicemente verificare se un'attività di trattamento è ancora coperta da una fase giuridica valida, si trova nella pratica privo di uno strumento che colleghi sistematicamente il contenuto dei documenti aziendali al registro. La verifica, quando viene fatta è perlopiù manuale, parziale e non ripetibile nel tempo.

Come verrà approfondito nell'analisi degli strumenti esistenti ([LINK A SEZIONE]), il panorama commerciale attuale non risolve in modo sufficiente questo problema per il contesto svizzero, lasciando aperto uno spazio applicativo concreto. Allo stesso tempo, come discusso nella motivazione architettuale ([LINK A SEZIONE]), la maturità raggiunta dalle tecniche di elaborazione del linguaggio naturale rende oggi percorribile, a un costo computazionale sostenibile, un approccio che pochi anni fa avrebbe richiesto un investimento sproporzionato.

Il progetto nasce dunque dall'intersezione di tre fattori: un obbligo normativo concreto, non pienamente automatizzabile con gli strumenti esistenti; uno spazio applicativo non coperto in modo adeguato dal mercato; e una maturità tecnologica che rende oggi realistico costruire un sistema di verifica della conformità basato sul confronto tra registro dichiarato e contenuto documentale effettivo.

## 1.5 Obiettivi del progetto

*Per ora solamente obiettivi del progetto, valutare se riformulare*

Il progetto intende produrre un sistema che renda visibile lo scarto tra le attività di trattamento dichiarate nel registro e la gestione effettiva dei dati nei documenti aziendali. In pratica, il prototipo dovrà:

- rilevare le categorie di dati personali presenti in documenti non strutturati, sulla base delle categorie canoniche della nLPD e di quelle dichiarate nel registro dei trattamenti;
- associare i documenti al trattamento corrispondente combinando più segnali;
- verificare la conformità ai periodi di retention dichiarati nel registro;
- segnalare categorie di dati personali non dichiarate nel registro e trattamenti non censiti;
- produrre un report leggibile dal Data Protection Officer dell'organizzazione.

## Capitolo 2

# Analisi dei requisiti

La struttura di questo capitolo si ispira allo standard ISO/IEC/IEEE 29148:2018 - Systems and Software Engineering - Life cycle processes - Requirements engineering [4].

### 2.1 Requisiti funzionali

#### 2.1.1 Acquisizione dell'input

Il sistema deve poter analizzare come input un insieme di file selezionati, una cartella, oppure un intero filesystem. L'acquisizione deve avvenire senza presupporre una struttura predefinita dell'albero di directory, supportando l'elaborazione ricorsiva di sottocartelle.

L'utente deve poter specificare percorsi multipli e/o pattern di esclusione (es. cartelle di sistema, file temporanei) per limitare la scansione ai soli percorsi rilevanti.

#### 2.1.2 Estrazione del testo

Il sistema deve estrarre il contenuto testuale dai documenti non strutturati (PDF, Word, Excel, immagini scansionate) [5] indipendentemente dal formato di partenza.

L'estrazione deve preservare, dove possibile, i metadati strutturali del documento (es. tabelle, intestazioni, numeri di pagina) necessari a contestualizzare le PII rilevate e a tracciarne la posizione nel report finale (cfr. 2.4.3).

#### 2.1.3 Rilevamento delle PII

Il sistema deve identificare le occorrenze di dati personali nel testo estratto, tramite una combinazione di meccanismi (regex, ML, NLP) [6, 7, 8] la cui composizione esatta è oggetto di definizione architetturale.

Il rilevamento deve coprire, come minimo, le categorie di dati personali rilevanti ai sensi della nLPD e del GDPR (es. dati identificativi, dati di contatto, identificatori numerici nazionali, dati

relativi alla salute, dati degni di particolare protezione secondo l'art. 5 lett. c nLPD [3] e l'art. 9 GDPR [2]).

#### **2.1.4 Aggregazione delle PII frammentate | DA VALUTARE**

Il sistema deve essere in grado di ricondurre frammenti di informazione dispersi all'interno di uno o più documenti a un'unica entità coerente (es. nome, identificativo, indirizzo di una stessa persona riportati in punti diversi del testo o in documenti diversi).

L'aggregazione deve basarsi su criteri verificabili (es. co-occorrenza, similarità semantica, identificatori univoci condivisi) e deve essere documentata nel report ai fini di tracciabilità.

#### **2.1.5 Costruzione di una knowledge base delle entità | DA VALUTARE**

A partire dalle PII estratte, il sistema deve costruire una rappresentazione strutturata delle entità rilevate nel sistema documentale (tramite NER [9]), che costituisce la base per il confronto con il ROPA.

La rappresentazione deve associare a ciascuna entità: le categorie di PII rilevate, i documenti di provenienza, e i riferimenti di posizione necessari per l'auditing.

#### **2.1.6 Ingestione del/i ROPA**

Il sistema deve accettare in input uno o più registri delle attività di trattamento (ROPA) in formato strutturato, da utilizzare come riferimento normativo autoritativo per il confronto con le PII rilevate nei documenti.

**Razionale.** Il ROPA costituisce, ai sensi dell'art. 30 GDPR e dell'art. 12 nLPD, il documento in cui l'organizzazione dichiara le proprie attività di trattamento. Senza la sua ingestione, il sistema non potrebbe effettuare alcuna verifica di conformità.

Il sistema deve supportare almeno i formati tabulari di uso comune (CSV, XLSX, JSON). Per ogni attività di trattamento, il formato di ingestione deve includere almeno i seguenti campi:

- categorie di dati personali previste;
- finalità del trattamento;
- periodo di conservazione dichiarato (o criteri per la sua determinazione);
- categorie di interessati;
- eventuali categorie di destinatari.

Il sistema deve segnalare all'utente, in fase di ingestione, eventuali campi obbligatori mancanti o valori non interpretabili, senza interrompere l'elaborazione per i record validi.

**Criterio di verifica.** Il requisito è soddisfatto se il sistema è in grado di importare correttamente un ROPA di riferimento in ciascuno dei formati supportati, estraendone tutti i campi previsti e segnalando i record incompleti.

### 2.1.7 Confronto dei risultati di analisi con il ROPA

Il sistema deve confrontare le entità e le categorie di dati personali effettivamente rilevate nei documenti con quanto dichiarato nel/i ROPA, verificando l'accuratezza e la coerenza tra dati trovati e dati dichiarati.

Il confronto deve produrre, per ciascuna entità/documento analizzato, un'associazione (anche parziale o nulla) con una o più attività di trattamento del ROPA, secondo criteri ed euristiche definiti in fase di progettazione architetturale.

### 2.1.8 Rilevamento delle anomalie di conformità

Il sistema deve identificare e classificare, sulla base del confronto di cui alla sezione 2.1.7, le seguenti tipologie di anomalie:

- categorie di PII rilevate ma non dichiarate nel ROPA per l'attività di trattamento associata;
- dati personali privi di una base giuridica/attività di trattamento associabile ("PII orfane");
- violazioni dei periodi di conservazione dichiarati nel ROPA (documenti contenenti PII oltre il termine di retention dichiarato).

Ogni anomalia rilevata deve essere classificata secondo una tipologia predefinita e associata a un livello di gravità/priorità.

### 2.1.9 Generazione report per DPO

Il sistema deve produrre, come output finale, un report strutturato e leggibile destinato al Data Protection Officer (DPO), contenente le anomalie di conformità rilevate.

Il report deve includere, per ciascuna anomalia: tipologia, documento/i coinvolti, attività di trattamento di riferimento (se presente) e la motivazione del rilevamento.

### 2.1.10 Persistenza e aggiornamento del registro delle PII rilevate

Il sistema deve mantenere un registro interno persistente delle PII rilevate, che associ a ciascuna occorrenza: il file sorgente, la posizione all'interno del documento, la categoria di PII e un identificatore temporale dell'analisi.

Il registro deve consentire il confronto tra esecuzioni successive dello stesso corpus documentale, al fine di rilevare:

- PII precedentemente segnalate che risultano rimosse o modificate nel documento sorgente (es. a seguito di un intervento correttivo da parte dell'organizzazione);
- nuove PII introdotte da documenti aggiunti o modificati dopo l'ultima analisi;
- documenti eliminati dal filesystem che contenevano PII precedentemente censite.

Il formato del registro deve essere strutturato e leggibile meccanicamente (es. database locale, JSON), per supportare sia la consultazione diretta sia l'integrazione con il report di conformità.

### 2.1.11 Feedback loop

Richiesto inserire un processo di iterazione tra i dipendenti e il DPO (gestito dal sistema), per segnalare all'interno dei documenti aziendali delle PII sfuggite al rilevamento automatico.

### 2.1.12 Analisi contestuale della struttura del filesystem

Il sistema deve considerare la posizione di ciascun documento all'interno della gerarchia del filesystem come segnale contestuale per l'associazione all'attività di trattamento. La struttura delle cartelle (nomi, profondità, organizzazione logica) può fornire indicazioni sulla finalità del trattamento e sulla legittimità della presenza di determinati dati personali in una posizione specifica.

A titolo esemplificativo, un documento contenente dati personali di un candidato (es. curriculum) collocato in una cartella destinata alla gestione dei turni deve essere segnalato come anomalia posizionale nel report, in quanto indicativo di una possibile violazione del principio di limitazione delle finalità.

### 2.1.13 Impieghi selettivi dell'AI generativa

Il sistema può impiegare modelli di AI generativa per attività mirate che beneficiano della comprensione semantica profonda, senza richiedere l'applicazione sistematica a ogni documento del corpus. In particolare:

- **Arricchimento dei ROPA:** qualora il registro delle attività di trattamento fornito in input contenga descrizioni sintetiche o generiche delle categorie di dati (es. "dati anagrafici" anziché "nome, cognome, data di nascita, indirizzo"), il sistema può utilizzare un LLM per espandere e normalizzare tali descrizioni [10], migliorando la granularità del confronto con le PII rilevate;
- **Analisi campionata:** il sistema può sottoporre a un LLM un sottoinsieme rappresentativo di documenti (es. uno ogni cento) per ottenere un'analisi contestuale approfondita, identificando PII deducibili dal contesto che sfuggirebbero ai metodi rule-based e NER;

- **Analisi della struttura del filesystem:** il sistema può utilizzare un LLM per interpretare la semantica dei percorsi e dei nomi di cartella, al fine di rilevare incoerenze tra la posizione del documento e il suo contenuto (cfr. 2.1.12).

Questi impieghi devono essere documentati e giustificati da studi comparativi (cfr.10) che ne attestino il valore aggiunto rispetto al costo computazionale sostenuto.

## 2.2 Requisiti normativi

### 2.2.1 Conformità ai principi di limitazione delle finalità e della conservazione

Il sistema deve supportare la verifica di conformità ai seguenti principi normativi:

- **Limitazione della finalità** (art. 5(1)(b) GDPR [2]; art. 6 cpv. 3 nLPD [3]): i dati personali devono essere raccolti per finalità determinate, esplicite e legittime, e non ulteriormente trattati in modo incompatibile con tali finalità;
- **Limitazione della conservazione** (art. 5(1)(e) GDPR [2]; art. 6 cpv. 4 nLPD [3]): i dati personali devono essere conservati per un arco di tempo non superiore al conseguimento delle finalità per le quali sono trattati.

**Razionale.** Questi due principi costituiscono il fondamento giuridico dell'intera logica di verifica del sistema: il confronto tra le PII rilevate nei documenti e quanto dichiarato nel ROPA è, nella sua essenza, una verifica che i dati trattati siano coerenti con le finalità dichiarate e che non siano conservati oltre i termini previsti.

La verifica deve operare su due assi:

1. **Asse delle finalità:** per ciascun documento analizzato, il sistema deve verificare che le categorie di PII rilevate rientrino tra quelle dichiarate per l'attività di trattamento associata;
2. **Asse della conservazione:** per ciascun documento contenente PII, il sistema deve confrontare la data del documento (o il suo ultimo aggiornamento) con il periodo di retention dichiarato nel ROPA per l'attività di trattamento associata.

**Criterio di verifica.** Il requisito è soddisfatto se, dato un corpus documentale di test con anomalie note (PII non dichiarate e documenti oltre retention), il sistema le identifica correttamente in entrambi gli assi.

### 2.2.2 Riferimento al registro delle attività di trattamento come fonte normativa

Il sistema deve trattare il/i ROPA forniti in input come riferimento normativo autoritativo per ogni valutazione di conformità. Il sistema non deve generare, inferire o modificare autonomamente le attività di trattamento: il ROPA rappresenta la *ground truth* dichiarativa dell'organizzazione [11].

**Razionale.** L'art. 30 GDPR [2] e l'art. 12 nLPD [3] impongono al titolare del trattamento la tenuta di un registro che documenti, tra l'altro, le categorie di interessati, le categorie di dati personali trattati, le finalità, la durata di conservazione e le categorie di destinatari. Il sistema si fonda su questo documento come base di confronto, senza sindacarne la correttezza né sostituirsi alla responsabilità del titolare nella sua compilazione.

Qualora il ROPA fornito risulti incompleto o incoerente (es. attività di trattamento prive di periodo di conservazione), il sistema deve:

- segnalare le carenze nel report, classificandole come anomalie del ROPA stesso;
- proseguire l'analisi limitatamente ai campi disponibili, senza interrompere l'elaborazione.

**Criterio di verifica.** Il requisito è soddisfatto se il sistema, ricevendo un ROPA con campi mancanti, produce le segnalazioni appropriate senza errori di esecuzione e senza alterare i dati del ROPA.

### 2.2.3 Copertura delle categorie di dati degni di particolare attenzione

Il sistema deve essere in grado di riconoscere le categorie di dati personali degni di particolare protezione secondo l'art. 5 lett. c nLPD [3] e le categorie particolari di dati personali secondo l'art. 9(1) GDPR [2], segnalandone la presenza con priorità elevata nel report delle anomalie, in considerazione del regime di consenso espresso richiesto (art. 6 cpv. 7 lett. a nLPD [3]; art. 9(2) GDPR [2]).

### 2.2.4 Posizionamento rispetto all'art. 32(1)(d) GDPR

Il sistema, nella sua esecuzione periodica, deve costituire un'implementazione tecnica della procedura di *test, verifica e valutazione regolare dell'efficacia delle misure tecniche e organizzative* prevista dall'art. 32(1)(d) GDPR [2] e, analogamente, dall'art. 8 nLPD [3].

**Razionale.** L'art. 32(1)(d) GDPR [2] qualifica come misura di sicurezza obbligatoria una procedura per testare e valutare regolarmente l'efficacia delle misure adottate. Un sistema che rileva periodicamente i dati personali nei documenti aziendali e ne verifica la coerenza con il registro dei trattamenti implementa, di fatto, questa procedura con riferimento alla conformità documentale.



Il perimetro del sistema è tuttavia limitato alla verifica di conformità documentale. Restano esplicitamente esclusi:

- funzioni di anonimizzazione o pseudonimizzazione dei dati;
- gestione degli incidenti di sicurezza (*data breach*);
- valutazione d'impatto sulla protezione dei dati (DPIA).

**Criterio di verifica.** Il requisito è soddisfatto se il sistema è in grado di essere eseguito periodicamente (es. tramite schedulazione automatica) producendo report comparabili tra esecuzioni successive.

## 2.2.5 Esclusione delle basi giuridiche dal perimetro di analisi automatica

Il sistema non deve determinare autonomamente la base giuridica applicabile a un trattamento (art. 6 GDPR [2]; art. 30-31 nLPD [3]). Tale valutazione resta di competenza esclusiva del DPO o del consulente giuridico dell'organizzazione.

**Razionale.** La determinazione della base giuridica richiede una valutazione contestuale di natura giuridica (consenso, interesse legittimo, obbligo legale, ecc.) che non è riducibile a un'analisi automatica del contenuto documentale. Come evidenziato nella sezione 2.2.1, il GDPR e la nLPD adottano inoltre approcci strutturalmente diversi alla liceità del trattamento, rendendo impossibile un'automazione generalizzata senza introdurre rischi di errore significativi.

Il sistema si limita pertanto a:

- segnalare la presenza di PII non riconducibili ad alcuna attività di trattamento dichiarata nel ROPA ("PII orfane");
- fornire al DPO gli elementi contestuali (documento, posizione, categoria di PII) necessari per una valutazione umana.

**Criterio di verifica.** Il requisito è soddisfatto se il sistema, in nessun caso, associa autonomamente una base giuridica a un trattamento e se le PII non associabili ad alcuna attività di trattamento vengono correttamente segnalate come "orfane".

## 2.3 Requisiti operativi

### 2.3.1 Elaborazione locale dei dati

Ogni dato analizzato dal sistema deve rimanere nell'infrastruttura in cui si trova inizialmente. Nessun contenuto documentale, testo estratto, PII rilevata o dato intermedio deve essere

trasMESSO a servizi esterni, API cloud o endpoint di inferenza remoti, in nessuna fase dell'elaborazione.

**Razionale.** I documenti analizzati possono contenere categorie di dati degni di particolare protezione ai sensi dell'art. 5 lett. c nLPD [3] (dati sulla salute, opinioni politiche, appartenenza religiosa, procedimenti penali, misure di assistenza sociale) e categorie particolari ai sensi dell'art. 9 GDPR [2]. La trasmissione di tali dati a servizi terzi introdurrebbe un trattamento ulteriore che richiederebbe una base giuridica propria, un'analisi dei rischi specifica e garanzie contrattuali (art. 28 GDPR [2]), vanificando la finalità stessa del sistema.

Il vincolo si applica a tutte le componenti del sistema, inclusi:

- i modelli di AI e NLP (cfr. 2.3.2);
- i moduli di estrazione del testo (cfr. 2.1.2);
- il registro interno delle PII (cfr. 2.1.10);
- la generazione del report finale (cfr. 2.1.9).

**Criterio di verifica.** Il requisito è soddisfatto se, durante l'esecuzione del sistema, non viene effettuata alcuna connessione di rete in uscita per la trasmissione di dati documentali o derivati. La verifica può essere condotta tramite analisi del traffico di rete o ispezione del codice sorgente.

### 2.3.2 Vincolo sui modelli AI impiegabili

I modelli di intelligenza artificiale impiegati dal sistema devono essere eseguibili interamente in locale, senza richiedere la trasmissione dei dati analizzati a servizi di inferenza esterni. Tale vincolo discende direttamente dal requisito di elaborazione locale (cfr. 2.3.1) e dalla natura potenzialmente sensibile dei dati trattati.

La scelta dei modelli deve bilanciare accuratezza e sostenibilità computazionale:

- per il rilevamento sistematico delle PII sull'intero corpus documentale, il sistema deve privilegiare approcci computazionalmente leggeri (rule-based, NER), eseguibili su hardware aziendale standard [12, 13];
- per attività selettive che richiedono comprensione semantica profonda (cfr. 2.1.13), il sistema può impiegare modelli generativi di dimensioni compatibili con l'esecuzione locale [10], limitandone l'applicazione a sottoinsiemi mirati del corpus.

La giustificazione della scelta architetturale dei modelli deve essere documentata attraverso studi comparativi che confrontino i risultati ottenuti con il consumo di risorse sostenuto (cfr. Capitolo 10).

### 2.3.3 Facilità di installazione e aggiornamento

Il sistema deve essere installabile e operativo in qualsiasi infrastruttura aziendale con un numero minimo di passaggi di configurazione, senza richiedere personalizzazioni specifiche per l'ambiente di destinazione.

**Razionale.** Il sistema è destinato a organizzazioni con livelli di maturità IT eterogenei. Un processo di installazione complesso o dipendente da configurazioni ad-hoc ridurrebbe l'adozione e renderebbe difficoltosa la manutenzione nel tempo.

In particolare, il sistema deve soddisfare i seguenti vincoli:

- l'installazione deve avvenire tramite un meccanismo standardizzato e riproducibile (es. container Docker, pacchetto con dipendenze integrate);
- la configurazione iniziale deve limitarsi alla specifica dei percorsi di input (documenti e ROPA) e delle preferenze di output;
- l'aggiornamento del sistema (nuove versioni, nuovi detector, aggiornamento dei modelli) deve poter avvenire senza perdita dei dati del registro interno (cfr. 2.1.10) e senza richiedere una reinstallazione completa;
- in caso di malfunzionamento, il sistema deve poter essere riportato a una configurazione funzionante nota senza interventi specialistici.

**Criterio di verifica.** Il requisito è soddisfatto se l'installazione del sistema su un ambiente pulito può essere completata seguendo la documentazione fornita, senza interventi manuali non documentati.

### 2.3.4 Estensibilità delle categorie e dei detector

Il sistema deve adottare un'architettura modulare che consenta l'aggiunta, la rimozione e la modifica delle categorie di PII rilevabili e dei relativi detector senza richiedere modifiche al codice sorgente del sistema.

**Razionale.** Le categorie di dati personali rilevanti variano in funzione del framework normativo applicabile (nLPD, GDPR, CCPA), del settore di attività dell'organizzazione e delle specifiche attività di trattamento dichiarate nel ROPA. Un sistema non estensibile costringerebbe l'organizzazione ad attendere un aggiornamento del prodotto per coprire categorie specifiche del proprio contesto.

L'estensibilità deve essere garantita su due livelli:

- **Categorie di PII:** l'operatore deve poter definire nuove categorie di dati personali (es. numero di matricola aziendale, codice paziente) specificandone il nome, la descrizione e le regole di rilevamento associate;

- **Detector:** il sistema deve supportare l'aggiunta di nuovi moduli di rilevamento (regole regex, modelli NER specializzati, dizionari) tramite un'interfaccia di configurazione dichiarativa (es. file YAML o JSON), senza richiedere competenze di sviluppo software.

**Criterio di verifica.** Il requisito è soddisfatto se un operatore non sviluppatore è in grado di aggiungere una nuova categoria di PII con il relativo detector, seguendo la documentazione fornita, e il sistema la rileva correttamente al successivo ciclo di analisi.

### 2.3.5 Minimizzazione dei dati trattati dal sistema stesso

Il sistema, nel corso della propria esecuzione, deve rispettare il principio di minimizzazione dei dati (art. 5(1)(c) GDPR [2]; art. 6 cpv. 2 nLPD [3]), limitando la quantità di informazioni personali che tratta e conserva internamente a quanto strettamente necessario per produrre il report di conformità.

In particolare:

- il sistema non deve duplicare integralmente i documenti analizzati; il contenuto estratto deve essere mantenuto in memoria per la sola durata dell'elaborazione;
- le PII rilevate devono essere riportate nel registro interno (cfr. 2.1.10) e nel report finale attraverso riferimenti posizionali e non tramite la riproduzione integrale del dato personale, salvo i casi in cui ciò sia necessario per la comprensibilità dell'anomalia;
- i dati intermedi (testo estratto, strutture temporanee) devono essere eliminati al termine dell'esecuzione.

### 2.3.6 Operatività senza addestramento iniziale (zero-training)

Il sistema deve essere operativo immediatamente dopo l'installazione, senza richiedere una fase di addestramento su dati specifici dell'organizzazione. Il rilevamento delle PII deve basarsi su conoscenze preconfigurate (modelli pre-addestrati, regole predefinite, dizionari standard) sufficienti a garantire un livello di detection accettabile per le categorie canoniche della nLPD e del GDPR.

Il sistema deve tuttavia supportare meccanismi di personalizzazione facoltativa, attivabili dopo il primo impiego:

- dizionari specifici per il framework normativo di riferimento (es. categorie nLPD, GDPR, CCPA);
- specializzazioni basate su documenti rappresentativi dell'organizzazione, per migliorare la precisione del rilevamento su terminologia e formati specifici del dominio aziendale.

## 2.4 Requisiti di qualità

I requisiti di qualità definiscono le proprietà non funzionali che il sistema deve soddisfare per essere considerato adeguato al contesto operativo previsto. Essi riguardano in particolare le prestazioni su volumi documentali realistici, l'affidabilità del rilevamento e la capacità di giustificare ogni anomalia segnalata.

### 2.4.1 Prestazioni su larga scala

Il sistema deve essere in grado di analizzare volumi documentali rappresentativi di un'organizzazione di medie dimensioni (nell'ordine delle migliaia di documenti) in tempi compatibili con un'esecuzione periodica (es. settimanale o mensile).

L'architettura deve prevedere meccanismi di parallelizzazione dell'elaborazione e, ove necessario, di analisi incrementale, in modo da evitare la rielaborazione integrale del corpus documentale a ogni esecuzione. Il tempo di elaborazione deve scalare in modo al più lineare rispetto al numero di documenti analizzati.

### 2.4.2 Precisione del rilevamento

Il sistema deve privilegiare un elevato valore di *recall* (sensibilità), al fine di minimizzare il rischio che dati personali effettivamente presenti nei documenti non vengano segnalati (falsi negativi). Un falso negativo in questo contesto equivale a una non-conformità non rilevata, con potenziali conseguenze sanzionatorie per l'organizzazione.

Al contempo, il tasso di falsi positivi deve essere mantenuto a un livello tale da non compromettere l'usabilità del report per il DPO: un numero eccessivo di segnalazioni errate riduce la fiducia nel sistema e ne vanifica l'utilità operativa.

Le soglie di *precision* e *recall* accettabili per ciascuna categoria di PII sono definite in fase di validazione sperimentale (cfr. Capitolo 7).

### 2.4.3 Tracciabilità delle anomalie

Ogni anomalia segnalata nel report deve essere completamente tracciabile fino alla sua origine. In particolare, il sistema deve associare a ciascuna anomalia:

- il documento sorgente (percorso, nome file, eventuale hash);
- la posizione specifica all'interno del documento (pagina, paragrafo, riga o cella, ove applicabile);
- la regola o il modello che ha generato il rilevamento (es. identificatore del detector, categoria di PII rilevata);

- l'attività di trattamento del ROPA a cui l'anomalia è stata associata (o l'indicazione esplicita di assenza di associazione).

La tracciabilità è condizione necessaria per consentire al DPO di verificare ciascuna segnalazione e, ove necessario, di utilizzare il report come evidenza documentale nell'ambito delle procedure di *accountability* richieste dal GDPR (art. 5(2)) e dalla nLPD.

## 2.5 Requisiti di interfaccia

### 2.5.1 Interfaccia a riga di comando (CLI)

Il sistema deve esporre un'interfaccia a riga di comando (CLI) come modalità primaria di interazione. La CLI deve consentire almeno le seguenti operazioni:

- specificare i percorsi dei documenti da analizzare e i pattern di esclusione;
- fornire il/i ROPA in input;
- selezionare il formato di output del report (es. JSON, PDF, CSV);
- avviare l'analisi e monitorarne lo stato di avanzamento.

L'interfaccia deve produrre messaggi di log strutturati e progressivi che consentano di monitorare l'avanzamento dell'elaborazione e di diagnosticare eventuali errori.

### 2.5.2 Formato di output del report

Il report generato dal sistema deve essere disponibile in almeno due formati complementari:

- **Formato strutturato** (es. JSON, CSV): leggibile meccanicamente, destinato all'integrazione con sistemi di governance, risk e compliance (GRC) o con strumenti di analisi già in uso nell'organizzazione;
- **Formato leggibile** (es. PDF, HTML): destinato alla consultazione diretta da parte del DPO, con impaginazione, indice delle anomalie e possibilità di navigazione per documento o per attività di trattamento.

**Razionale.** Il DPO necessita di un documento consultabile e presentabile (es. in sede di audit o di comunicazione con l'autorità di controllo), mentre l'integrazione con sistemi GRC richiede un formato parsabile automaticamente. I due formati rispondono a esigenze distinte e complementari.

Entrambi i formati devono contenere le medesime informazioni e devono essere generati contestualmente al termine dell'analisi, senza richiedere esecuzioni separate.

**Criterio di verifica.** Il requisito è soddisfatto se, al termine di un'analisi di test, il sistema produce entrambi i formati e il contenuto informativo è equivalente tra i due.

## Capitolo 3

# Stato dell'arte

### 3.1 Background tecnologico

Questa sezione è specificamente indicata per inserire definizioni e spiegazioni su argomenti discussi successivamente.

#### 3.1.1 Spiegazione supervised vs unsupervised

Come spiegato in uno dei testi cardine del machine learning, redatto da Goodfellow et al. [14], queste due metodologie di apprendimento si distinguono in base al tipo di *esperienza* che l'algoritmo acquisisce a partire dai dati durante l'addestramento. Sono definite come segue:

- per **Supervised learning** si intende quel paradigma di apprendimento automatico in cui l'algoritmo viene addestrato su un insieme di dati in cui ogni esempio, oltre alle sue caratteristiche, è associato a un'etichetta o a un valore target noto a priori. Il modello apprende quindi una funzione che mappa le caratteristiche di input all'etichetta corrispondente, sulla base di esempi già classificati o annotati. Un caso tipico è quello di un classificatore addestrato a riconoscere la specie di appartenenza di un fiore a partire da misurazioni morfologiche etichettate.
- per **Unsupervised learning** si intende quel paradigma in cui l'algoritmo opera su un insieme di dati privo di etichette, con l'obiettivo di individuare autonomamente strutture, regolarità o proprietà latenti presenti nei dati stessi. Nel contesto del deep learning, questo si traduce spesso nel tentativo di apprendere — in modo esplicito (ad esempio tramite stima di densità) o implicito (ad esempio per compiti di generazione o denoising) — la distribuzione di probabilità sottostante ai dati. Altri algoritmi non supervisionati svolgono invece compiti diversi, come il clustering, che consiste nel raggruppare gli esempi del dataset in base alla loro similarità.

Nel contesto specifico della NER, l'approccio supervisionato mostra miglioramenti quantificabili rispetto alle alternative zero-shot. La curva di apprendimento dei modelli Transformer pre-addestrati è ripida: con soli  $\sim 100$  esempi annotati, l' $F1$ -score aumenta di circa 5.6 punti rispetto alla baseline zero-shot, mentre con 500–1000 esempi si raggiunge tipicamente un  $F1$  del 90–95%. I rendimenti diventano decrescenti oltre i 2000 esempi, dove il modello raggiunge la saturazione dominio-specifica ( $F1 \approx 95$ –99%). Fine-tunare su un dominio specifico comporta miglioramenti particolarmente netti per le categorie inizialmente mal coperte: le categorie con riconoscimento zero-shot scarso possono mostrare incrementi  $F1$  fino al 57–80%.

### 3.1.2 Pre-training vs fine-tuning

Il paradigma pre-training/fine-tuning è stato reso centrale nell'NLP moderno dal lavoro di Devlin [15], che lo applicano al modello BERT (Bidirectional Encoded Representations from Transformers). Le due fasi si articolano come segue:

- per **pre-training** si intende la fase iniziale di addestramento in cui il modello apprende rappresentazioni linguistiche generali a partire da grandi quantità di testo non etichettato, tramite obiettivi di tipo *self-supervised* (ad esempio indovinare delle parole mascherate casualmente all'interno di una frase). In questa fase il modello non è ancora specializzato su alcun compito specifico: l'obiettivo è costruire una rappresentazione del linguaggio sufficientemente generale per poter essere riutilizzata per molteplici task.
- per **fine-tuning** si intende la fase successiva, in cui i parametri del modello pre-addestrato vengono ulteriormente ottimizzati su un dataset etichettato e di dimensioni ridotte, specifico per il compito che si intende risolvere. A differenza del pre-training, che richiede risorse computazionali ingenti, il fine-tuning può avvenire con un costo computazionale contenuto, poiché parte da una rappresentazione linguistica già appresa e la adatta al task target, spesso aggiungendo un solo livello di output specifico per il compito.

### 3.1.3 Spiegazione zero-shot learning

Il concetto di zero-shot learning è stato formalizzato in modo sistematico da Xian et al. [16], che lo definiscono come quel paradigma di apprendimento in cui un modello viene valutato su classi (o, nel caso della Named Entity Recognition, su tipologie di entità) che non erano presenti nel suo insieme di addestramento.

A differenza dei paradigmi supervised e unsupervised descritti in 3.1.1, lo zero-shot learning non riguarda la presenza o assenza di etichette nei dati di training, bensì la capacità del modello di generalizzare a categorie mai osservate, sfruttando informazioni semantiche



ausiliarie (ad esempio descrizioni testuali delle classi target) anziché esempi annotati specifici per quelle categorie. Tale capacità si distingue dal *one-shot* e dal *few-shot learning*, in cui il modello dispone rispettivamente di uno o di un numero ridotto di esempi annotati per le classi target [17].

### 3.2 Definizione e inquadramento del problema: Dalla Data Anonymization alla Data Governance

da capire cosa mettere in questa sezione, per non essere ripetitivo con quella del contesto  
Da definire il problema tecnico dell'astrazione. (pensiero grezzo) I documenti non strutturati soffrono del problema del "Domain-Silo" [18]: i sistemi di detection falliscono perché addestrati su dati specifici e non riescono a generalizzare su testi eterogenei. Il problema centrale non è "leggere" il documento, ma togliere le ambiguità dalle informazioni in base al contesto in cui si trovano. *RIFORMULARE PER UNIRE TUTTO*

### 3.3 Compliance checking automatizzato

Sezione contenente metodi per confrontare il ROPA con i dati effettivamente all'interno dei dati.[11] **MAGARI DA SPOSTARE**

### 3.4 Approcci tecnici di PII detection

Per rilevare le PII, esistono più metodi e strategie, tutte ampiamente discusse in studi accademici. Ognuna di queste ha dei punti di forza e di debolezza, infatti esiste una area di problemi dove ogni singola opzione diventa la migliore, riducendo o addirittura annullando gli effetti negativi. (Approfondimento al capitolo 10 [DA LINKARE NEL DOCUMENTO])

Le soluzioni in questione sono:

#### 3.4.1 Recognition rule-based

Approccio più semplice e rule-based. La detection delle PII è solamente affidata a regole di pattern-matching e meccanismi simili. Come si può già intuire, questo approccio, per alcune categorie di dati sensibili, è particolarmente efficace: la massima performance si ottiene quando si trattano dati strettamente formattati in determinati modi (IBAN, AVS, codice fiscale etc...). Non appena i testi diventano liberi e non strutturati, allora l'accuratezza crolla. [18, Sezione 5.2] Questo approccio tuttavia, ha dei problemi seri che non possono essere trascurati: [da capire se mettere lista oppure lasciare testo] categorie nettamente più difficili da trovare (nomi propri per esempio, in quanto si baserebbero su regole facilmente mal-interpretabili e con un alto numero di falsi positivi (es. lettera maiuscola) [IDEA: libreria

per checkare se una parola sia nel dizionario italiano/inglese. SE NO, ALLORA NOME PROPRIO])

**Vantaggio:** più veloce in assoluto tra tutte le soluzioni.

### 3.4.2 Recognition con NLP - NER

I modelli di Natural Language Processing (NLP), tramite la Named Entity Recognition (NER), classificano le entità testuali analizzando la struttura logica della frase. Architetture basate su Transformers (es. BERT) superando i limiti delle regole, comprendendo il contesto e raggiungendo accuratezze fino al 99.55% [19].

**Vantaggio:** eccellente bilanciamento tra comprensione del testo ed efficienza computazionale.

**Svantaggio:** Rischio di calo prestazionale su dati aziendali particolarmente specifici senza fare fine-tuning su dataset simili.

### 3.4.3 Recognition con AI generativa

Ultima soluzione "pura" è l'utilizzo di LLM con AI generativa per l'individuazione di PII. Questo approccio, fortemente documentato e discusso, è senza dubbio il migliore per quanto riguarda solamente le performance. Infatti, seppur riesce ad avere un F1-score e una recall senza precedenti, ha un costo computazionale e di risorse senza precedenti, spesso ingestibile per la maggior parte delle macchine. Gli unici modi per rendere accettabili tempi di esecuzione è di down-scalare i modelli utilizzati, riducendo contesto e "intelligenza" dello stesso. Seppur di aiuto, più si scende con la dimensione e il peso dei modelli, più il vantaggio di usare gli LLM si assottiglia, fino ad azzerarsi rispetto all'uso dell'NLP.

Tuttavia, gli LLM hanno un vantaggio unico per quanto riguarda un aspetto fondamentale nel nostro problema: la presenza nativa del 'contesto'. Infatti gli LLM possiedono una comprensione semantica avanzata del linguaggio naturale. Tramite il paradigma Zero-Shot, identificano PII deducibili puramente dal contesto verbale (es. dedurre "minorenne" dalla frase "mio figlio, nato 3 anni fa") senza alcun addestramento. Inoltre, offrono interpretazioni del loro operato, agevolando gli audit di conformità [10].

### 3.4.4 Limitazioni nella soluzione

Come visto nella sezione precedente, la soluzione parzialmente migliore sembrerebbe essere la detection con NLP. Questo perché riesce ad avere una percentuale di matching particolarmente alta, senza aver bisogno della quantità ingestibilmente alta di risorse dell'AI generativa.

Tuttavia, questa soluzione diventa praticamente insignificante se teniamo in considerazione l'aspetto dello "**Zero training**". Infatti, da requisiti [LINK AI REQUISITI], il nostro sistema di

detection deve essere ready-to-use non appena installato, garantendo una buona percentuale di detection senza aver bisogno dei dati su cui sta lavorando. Le metodologie NLP - NER hanno alla base proprio la knowledge dei dati che si stanno analizzando.

### 3.4.5 Soluzioni ibride

Per soddisfare il vincolo estremamente stringente dello "Zero-Training", bilanciando l'elevata richiesta di risorse dell'AI generativa e la rigidità dei sistemi rule-based, lo **standard industriale** prevede un'architettura ibrida (es. Microsoft Presidio) [20]

### 3.4.6 Confronto empirico degli approcci

Le sezioni precedenti presentano ciascun approccio in termini qualitativi. Per motivare la scelta architetturale in modo rigoroso, è necessario un confronto quantitativo basato su evidenze empiriche dalla letteratura recente. Le metriche considerate sono precisione (P), recall (R), F1-score, costo energetico di inference e necessità di dati annotati.

#### 3.4.6.1 Prestazioni dei sistemi rule-based

Le espressioni regolari raggiungono alta precisione su pattern strutturati come email, numeri di telefono e indirizzi IP, specialmente se accompagnate da post-processing per eliminare falsi positivi sistematici (ad esempio ISBN confusi con numeri di telefono) [21]. Tuttavia, il limite strutturale è la *brittleness*: i detectors rule-based non considerano il contesto del testo circostante e falliscono sistematicamente su PII contestuali [22]. La letteratura di survey su NER conferma il pattern: per i metodi rule-based la precisione è tipicamente alta, mentre il recall tende a essere basso a causa di regole domain-specific; il processo di introduzione di nuove regole è costoso [23].

#### 3.4.6.2 Prestazioni dei modelli NER supervisionati

Con corpus annotati adeguati, i modelli encoder fine-tuned raggiungono le prestazioni più elevate in assoluto tra tutti gli approcci considerati. In un benchmark comparativo su documenti clinici, BERT, ModernBERT e ClinicalBERT raggiungono tutti  $P = 0.99$  e  $R = 0.99$  ( $CIRE \approx 0.99$ ), con throughput di 1528–2446 token/secondo e costo energetico di inference nettamente inferiore ai modelli generativi [24]. Un modello DeBERTa fine-tuned sul dataset *ai4privacy* raggiunge  $F1 = 0.9757$  su un benchmark PII multi-dominio [25].

Su documenti finanziari non strutturati (audit report, fatture), una pipeline ibrida NLP rule-based + ML + NER custom raggiunge  $P = 94.7\%$ ,  $R = 89.4\%$ ,  $F1 = 91.1\%$  su dataset sintetici, con il 93% di accuratezza su documenti reali [26].

Il principale ostacolo non è il costo di inference (basso dopo il training) ma il costo di annotazione del corpus: le soluzioni supervisionate richiedono tipicamente un corpus annotato di

grandi dimensioni [27]. Questo costo è però da sostenersi una tantum (fine-tuning), non per ogni documento analizzato (distinzione fondamentale rispetto all'inference LLM, ricorrente).

### 3.4.6.3 Prestazioni dei modelli NER zero-shot

GLiNER (cfr. 3.1.3) usa un encoder bidirezionale (DeBERTa) con un meccanismo di span-extraction (individuare inizio e fine di una label, invece di processare parola per parola) prompt-style (inserire le etichette da estrarre come testo, senza averne di predefinite nell'architettura del modello): le label vengono fornite come input testuale e il modello identifica span corrispondenti nel documento senza retraining [28]. Test su dataset PII multi-domain mostrano GLiNER-base a circa l'81% di F1, superiore ad approcci spaCy o regex standard, con recall particolarmente elevato su ID numerici e date [29]. Il modello `gliner-pii-base-v1.0` raggiunge  $F1 = 80.99\%$  ed è ottimizzato per applicazioni privacy-focused in cui i servizi NER cloud pongono rischi di conformità [30].

Tuttavia, la specificità di dominio rimane determinante anche per approcci zero-shot: su testo clinico, GLiNER scende a circa  $F1 = 0.41$ , perdendo oltre il 50% delle entità PHI rispetto ai modelli domain-specific [31]. Questo impone una valutazione empirica obbligatoria sul corpus aziendale target prima di escludere il fine-tuning.

### 3.4.6.4 Prestazioni dell'AI generativa

GPT-4o, LLaMA 3.3 70B e LLaMA 3.1 8B raggiungono tutti recall medio superiore a 0.90, ma la precisione rimane un problema irrisolto: anche il top performer GPT-4o raggiunge soltanto  $P = 0.579$  su dataset educativi [32]. Su benchmark strutturati multi-task (PII-Bench), GPT-4o con metodi avanzati (Self-CoT, Self-Consistency) raggiunge  $F1 \approx 0.76\text{--}0.77$ , con Llama 3.1 e Qwen 2.5 in linea [18].

Il problema principale per il contesto di questa tesi è il **costo energetico ricorrente**. Luccioni, Jernite e Strubell mostrano una distinzione netta tra modelli discriminativi task-specific — con emissioni molto inferiori — e modelli generativi decoder-only: la generazione di testo richiede circa 0.047 kWh per 1000 query [33]. Questo costo si moltiplica per ogni documento analizzato nel filesystem aziendale ed è ricorrente (ogni nuova analisi, ogni re-scan), mentre il fine-tuning di un encoder è un costo one-shot. A parità di F1, RoBERTa costa circa \$0.044 per 1000 esempi contro \$13.50 di GPT-4 — un rapporto di circa 300:1 [34].

### 3.4.6.5 Convergenza verso la pipeline ibrida

La convergenza della letteratura recente indica la pipeline ibrida come soluzione ottimale per il rilevamento PII in contesti di compliance. Il sistema RECAP (NeurIPS 2025) combina regex deterministiche con LLM context-aware in un framework modulare a tre fasi: (1) rilevamento regex, (2) classificazione NER, (3) risoluzione ambiguità via LLM. RECAP supera i modelli

NER fine-tuned dell'82% e i LLM zero-shot del 17% in weighted F1-score su 13 lingue low-resource [7].

Un sistema ibrido indipendente (CHPDA) documenta lo stesso principio: le regex eccellono su pattern chiaramente definiti ma mancano di flessibilità per gestire complessità contestuali; i modelli NER eccellono nell'identificare entità ambigue come nomi e indirizzi, difficili da catturare con regex, ma producono falsi positivi senza pattern guida. La combinazione risolve i limiti di entrambi [35].

La letteratura non esclude l'AI generativa in assoluto, ma ne circoscrive il ruolo: l'impiego su casi ambigui come supervisor di una pipeline ibrida è documentato come cost-effective [7]. L'esclusione riguarda l'inferencesistemica su tutto il corpus, non l'impiego selettivo su un sottoinsieme di casi irrisolti.

### 3.4.6.6 Matrice di confronto sintetica

La Tabella 3.1 riassume le evidenze empiriche discusse nelle sezioni precedenti.

Tabella 3.1: Confronto empirico degli approcci di PII detection basato su evidenze dalla letteratura.

| Approccio               | P         | R           | F1 tipico   | Costo inf. | Corpus ann. | Energia training              | Energia / 1k query       |
|-------------------------|-----------|-------------|-------------|------------|-------------|-------------------------------|--------------------------|
| Regex / rule-based      | Alta      | Bassa-media | 0.60–0.75   | Minimo     | No          | Nessuno                       | Trascurabile             |
| NER supervised          | 0.95–0.99 | 0.89–0.99   | 0.94–0.99   | Basso      | Sì (grande) | Basso (one-shot) <sup>a</sup> | ~0.002 kWh <sup>b</sup>  |
| NER zero-shot (GLiNER)  | Media     | Media       | ~0.81       | Basso      | No          | Nessuno <sup>c</sup>          | ~0.002 kWh <sup>b</sup>  |
| LLM generativo (GPT-4o) | 0.58      | >0.90       | 0.70–0.77   | Altissimo  | No          | Altissimo <sup>d</sup>        | ~0.047 kWh <sup>b</sup>  |
| Pipeline ibrida         | Alta      | Alta        | +82% vs NER | Medio      | Opzionale   | Basso (NER component)         | Basso-medio <sup>e</sup> |

<sup>a</sup> Il fine-tuning di un encoder richiede ~44 h GPU totali su A100; il costo è one-shot e non ricorrente [24]. <sup>b</sup> Dati misurati su A100: text classification ~0.002 kWh/1k inf., text generation ~0.047 kWh/1k inf. [33]. <sup>c</sup> GLiNER usa un encoder pre-addestrato senza fine-tuning task-specific [28]. <sup>d</sup> Il pre-training di LLM generativi richiede ordini di grandezza più energia dell'inference; la parità training/inference si raggiunge dopo 200–590 M query [33]. <sup>e</sup> Regex + NER encoder con LLM solo su casi ambigui: il costo è dominato dalla componente NER [7].

## 3.5 Analisi del training

Storicamente, i modelli utilizzati per l'estrazione di informazioni si dividono in due macrocategorie: supervised e unsupervised (cfr. 3.1.1). Ognuno dei due approcci presenta vantaggi e svantaggi in termini di scalabilità. Numerosi studi, come quello di Al Qahtani [36], hanno dimostrato come i modelli supervisionati garantiscano performance superiori su pattern noti, ma richiedano onerose fasi di etichettatura manuale per adattarsi a nuovi scenari.

Tuttavia, nel contesto specifico della Named Entity Recognition (NER) moderna, il dibattito si è spostato su due paradigmi di training più evoluti per i modelli Transformer:

### 3.5.1 Pre-training e fine-tuning (Paradigma classico)

Il paradigma tradizionale prevede l'utilizzo di un modello linguistico pre-addestrato su vasti corpus testuali, il quale viene poi adattato (*fine-tuned*) tramite un dataset supervisionato

specifico per il dominio di interesse (es. dati finanziari o medici). Sebbene garantisca accuratezza elevata, questo approccio introduce due criticità:

- **Costi di annotazione:** l'adattamento richiede dataset etichettati massicci, che nel caso delle PII comporta spesso l'intervento manuale di esperti e solleva problematiche di privacy intrinseche alla manipolazione di dati reali.
- **Perdita di generalizzazione (Catastrophic Forgetting):** la specializzazione spinta su un singolo formato documentale può compromettere la capacità del modello di generalizzare su testi imprevisti.

Questi vincoli risultano particolarmente critici in ambienti operativi ristretti. Come evidenziato dallo studio di Zhang et al. [37] sul rilevamento di PII in architetture *smart edge computing*, l'esigenza di eseguire inferenza locale e decentralizzata richiede modelli estremamente robusti che non obblighino a continui cicli di riaddestramento per coprire nuove categorie di dati sensibili.

### 3.5.2 Span-matching e Zero-shot (Il paradigma GLiNER)

Per superare i colli di bottiglia del fine-tuning, la letteratura ha esplorato modelli capaci di identificare entità senza addestramento pregresso sulle etichette specifiche (Zero-shot). Architetture recenti, come GLiNER [28], sfruttano encoder bidirezionali leggeri per eseguire uno *span-matching*. In questa modalità, al modello viene passato sia il documento da analizzare sia le descrizioni testuali delle PII da trovare (es. "Numero di previdenza sociale"). Il modello calcola la similarità semantica tra le parole del testo e la descrizione dell'etichetta cercata, identificando il dato personale in tempo reale. Questo paradigma è perfettamente allineato alle necessità di flessibilità e privacy locale teorizzate da Zhang [37], eliminando il costo del fine-tuning e permettendo di estendere le categorie ricercate semplicemente aggiornando la lista di istruzioni testuali in input.

## 3.6 Sfide nell'elaborazione documentale

Sezione con strumenti considerati per trasformare file non strutturati in formati facilmente leggibili da regex o, più importante, AI (NLP, generativa etc...)

### 3.6.1 Docling

Spiegone di Docling

### 3.6.2 Altro...

Spiegno di altre tecnologie (che ora non ricordo)

## 3.7 Panoramica dei sistemi esistenti

L'analisi dello stato dell'arte evidenzia una profonda spaccatura tra gli strumenti open-source, spesso focalizzati su un singolo task tecnici (anonimizzare o estrazione brutta), e le suite commerciali, ricche di feature ma close-source e inaccessibili.

### 3.7.1 Sistemi open-source

- **Microsoft Presidio** è un framework open-source sviluppato da Microsoft, diventato uno standard industriale per l'identificazione e l'anonimizzazione. Offre un'architettura modulare basata su classi estensibili come *EntityRecognizer* (per i modelli di Machine Learning) e *PatternRecognizer* (per il pattern matching classico) [38]. Il motore di rilevamento (*Analyzer*) è disaccoppiato dal componente di anonimizzazione (*Anonymizer*), include riconoscitori pre-costruiti anche per il contesto italiano (ad esempio il codice fiscale, con validazione a checksum) e consente di collegare motori NER esterni.

Il suo **limite rispetto allo scopo del progetto** non è tecnologico ma di *finalità*: nasce per la rilevazione e l'anonimizzazione del dato, non per la governance e la verifica di conformità. Non implementa alcuna logica di registro dei trattamenti (ROPA), di gap analysis o di reportistica per il DPO, e non copre nativamente identificatori del contesto svizzero (ad esempio il numero AVS). Il suo motore di detection resta però riutilizzabile come componente di un sistema più ampio: questa possibilità è valutata esplicitamente nel Capitolo 6 (§6.2).

- **GLiNER**: architettura Zero-Shot basata su Transformers, in grado di identificare PII passandole dinamicamente come query, senza addestramento. Le sue iterazioni recenti (GLiNER2-PII) mostrano prestazioni eccellenti in contesti multilingua [28].

**Limiti**: è esclusivamente un "motore algoritmico". Prende stringhe in input ed estrae etichette. Non implementa il parsing di documenti (PDF/Word), non genera reportistiche strutturate e non possiede alcuna logica di compliance (ROPA). [39]

- **Scrubadub / Datafog**: strutture open-source modulari. Scrubadub utilizza un'architettura a *Detector* multipli (Regex, detector predefiniti, NLP esterni) [40].

**Limiti**: sono fortemente legati al test-masking e all'oscuramento. Spesso si affidano pesantemente al pattern matching deterministico (Regex) (cfr:3.4.1), una tecnologia ormai insufficiente da sola per gestire documenti destrutturati e ambigui.

### 3.7.2 Sistemi commerciali

L'analisi dei player di mercato è fondamentale per comprendere quali caratteristiche vengono ricercate dalle aziende per quanto riguarda la compliance. Le soluzioni commerciali offrono architetture olistiche, ma a costi e configurazioni strutturali spesso incompatibili con le Piccole e Medie imprese o con vincoli stretti di privacy locale.

- **Varonis:** piattaforma leader mondiale per la Data Security Posture Management (DSPM). Implementa un motore ibrido che vanta un'accuratezza del **98%** su dati strutturati e non strutturati (SharePoint, OneDrive, NAS) senza necessità di training sui dati del cliente [41]. Tra le feature distintive spicca la User and Entity Behavior Analytics (UEBA), che monitora pattern anomali di accesso ai file sensibili [42], unita a scansioni *incrementali* per abbattere i costi computazionali.

**Limiti:** Si tratta di un sistema massiccio focalizzato sul *controllo degli accessi* e la Data Security delle reti aziendali. I costi (circa 80.000 CHF/anno [43]) e la sua architettura chiusa lo rendono sovradimensionato e inadatto allo scope del progetto.

- : piattaforma di altissimo livello per la Data Privacy e Governance. Il suo punto di forza risiede nell'**Identity-aware discovery**: non si limita a trovare un dato sensibile, ma correla i record a specifiche persone fisiche (Data Subjects) incrociando diverse fonti [44]. Utilizza una tecnologia proprietaria (*Hyperscan*) per prioritizzare lo scanning tramite Machine Learning. Soprattutto, supporta la **gestione dei ROPA automatizzata**, mappando i dati scoperti contro la conformità normativa e gestendo le policy di retention (cancellando dati "redundant, obsolete, trivial" o semplicemente scaduti) [45].

**Limiti:** struttura enterprise dai costi preclusivi su preventivo. Per molte operazioni di classificazione si affida ad architetture Cloud o Ibride, che sollevano importanti problematiche di Data Sovereignty, scontrandosi con il vincolo del progetto di mantenere tutta l'inference all'interno dell'infrastruttura aziendale cliente.

- **PII Tools:** soluzione verticale sulla singola PII detection. Offre un approccio Machine Learning che, secondo l'azienda, riduce i falsi positivi delle classiche Regex assicurando maggiore comprensione del contesto [46]. Risulta particolarmente interessante per le PMI poiché distribuibile interamente **on-premise via Docker in pochi minuti** e garantisce una mappatura che indica la localizzazione spaziale esatta del dato all'interno del documento [47].

**Limiti:** pur essendo leggero, resta un software *black-box* a pagamento. Manda di trasparenza e non offre flessibilità per scambiare il modello AI sottostante qualora se ne presentasse uno migliore.

### 3.8 Sintesi del gap e posizionamento del progetto

Alla luce di questa panoramica, il **gap nel mercato** risulta evidente. Le organizzazioni, in particolare le PMI svizzere, si riscontrano con un panorama fortemente polarizzato:

1. **Soluzioni open-source:** Rilevano i dati in locale ma lo fanno con l'ottica prioritaria dell'*anonimizzazione* (Presidio), oppure offrono solo modelli potenti linguistici disconnessi da qualsiasi logica di governance e reportistica aziendale (GLiNER).



2. **Soluzioni Commerciali:** Dimostrano quali siano le reali necessità delle aziende, introducendo l'Identity-aware discovery, l'automazione dei ROPA, lo scanning incrementale e le dashboard per DPO. Tuttavia, lo fanno imponendo ecosistemi Black-box, costi esorbitanti e massicce dipendenze da Cloud/API di terze parti, con conseguenti problematiche di *Data Sovereignty*.

Posizionamento del progetto: il software proposto si inserisce al centro di questo divario. L'obiettivo è fornire uno strumento open-source ed eseguibile **esclusivamente in locale** (on-premise), rispondendo all'esigenza di confidenzialità totale. Abbandonando il paradigma dell'anonimizzazione dei tool, il ...

Sfruttando parser moderni (cfr.3.6) per affrontare dati strutturati e motori NLP Zero-Shot (cfr.3.1.3) per eliminare i costi di training descritti precedentemente. Il sistema non si limiterà a scoprire le PII, ma fungerà da ponte tra il dato reale e le policy aziendali (ROPA), fornendo un quadro clinico dell'aderenza normativa aziendale.

da inserire tabella riassuntiva (o paragrafo comparativo) che fa capire cosa "fanno gli altri" e "cosa manca".





## Capitolo 4

# Analisi dei rischi

### 4.1 Rischi di progetto

- 4.1.1 Disponibilità e qualità dei dataset di valutazione
- 4.1.2 Complessità dell'integrazione multi-approccio
- 4.1.3 Costo computazionale e tempi di elaborazione
- 4.1.4 Dipendenza da modelli e librerie di terze parti
- 4.1.5 Carenza di competenze specialistiche
- 4.1.6 Scope creep e requisiti in evoluzione

### 4.2 Rischi di prodotto

- 4.2.1 Accuratezza insufficiente nella detection delle PII
- 4.2.2 Falsi positivi e impatto sull'usabilità
- 4.2.3 Falsi negativi e mancata rilevazione di PII critiche
- 4.2.4 Generalizzazione cross-domain (domain-silo problem)
- 4.2.5 Supporto multilingue e multilocalizzazione
- 4.2.6 Scalabilità su filesystem di grandi dimensioni
- 4.2.7 Qualità e completezza dei ROPA in input
- 4.2.8 Conformità normativa e aggiornamento dei framework legali
- 4.2.9 Sicurezza e protezione dei dati durante l'analisi

### 4.3 Valutazione dei rischi

- 4.3.1 Criteri di classificazione

4.3.2 **Matrice probabilità-impatto** Strumenti di analisi e valutazione dei rischi strutturati aziendali

### 4.4 Strategie di mitigazione

## Capitolo 5

# Architettura del sistema

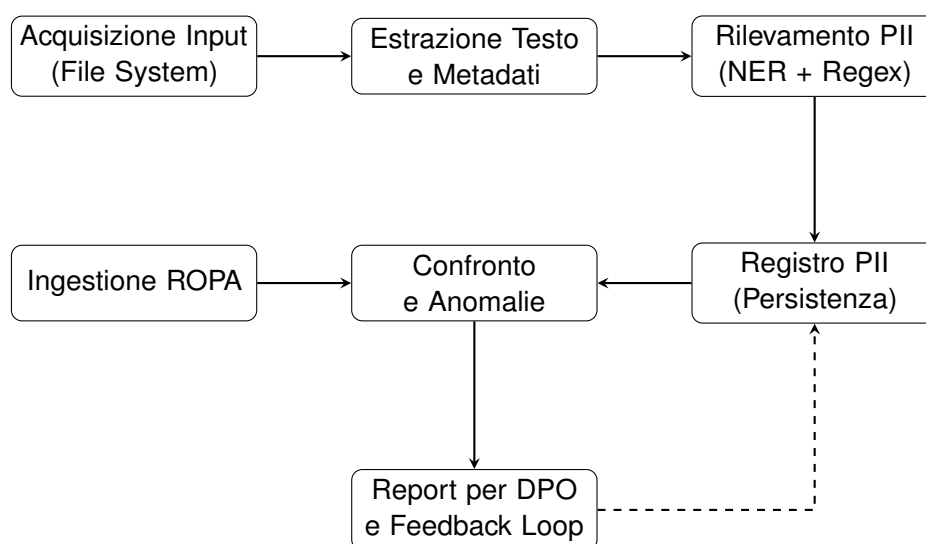


Figura 5.1: Pipeline di esecuzione del sistema

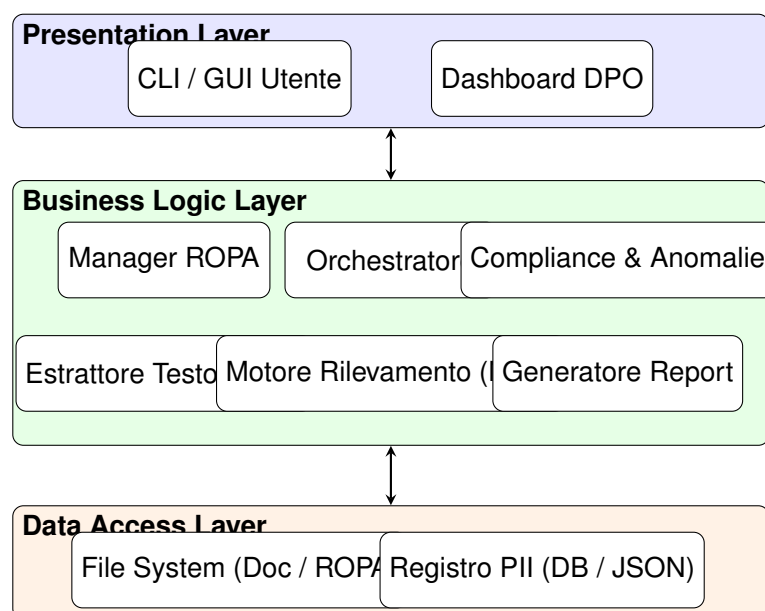


Figura 5.2: Suddivisione in moduli dell'architettura

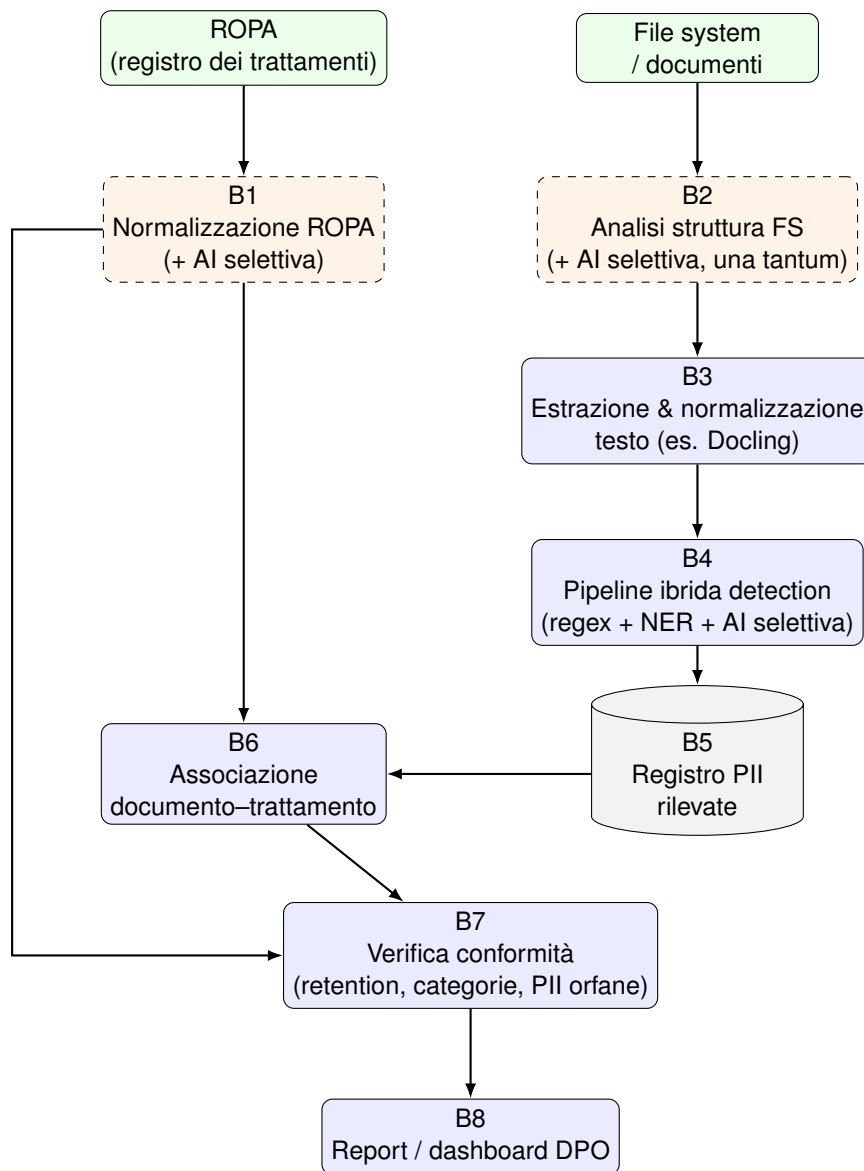


Figura 5.3: Architettura a macro-blocchi del sistema (bozza)

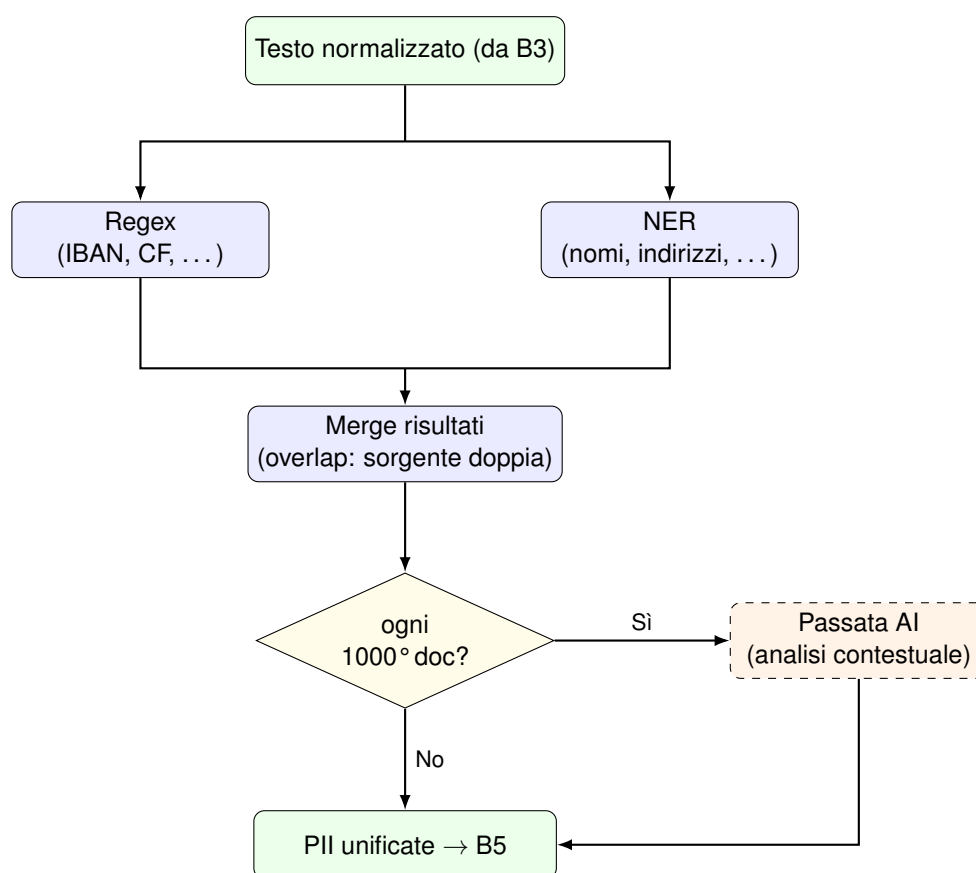


Figura 5.4: Dettaglio del blocco B4: pipeline ibrida di rilevamento PII



## 5.1 Ingestione e modello dati del ROPA

Il blocco B1 della Figura 5.3 acquisisce il ROPA (*Record of Processing Activities*, il registro delle attività di trattamento) e lo trasforma in una rappresentazione interna. Non è una fase accessoria: il ROPA è il termine di paragone *atteso* rispetto al quale la verifica di conformità (B7) confronta le PII effettivamente rilevate nei documenti. La sua struttura dati condiziona quindi ciò che il sistema è in grado di verificare. Questa sezione motiva l'approccio scelto per modellarlo.

### 5.1.1 Strutturazione a monte o delega all'AI

L'ingestione del ROPA ammette due strategie agli estremi opposti. Nella prima la **struttura dati è definita a monte**: il sistema impone uno schema noto e l'ingestione lo popola in modo deterministico a partire da un ROPA già compilato. Nella seconda, **totalmente agentica**, i documenti del ROPA vengono forniti così come sono a un modello generativo, delegando a esso l'individuazione della struttura — l'approccio «si immettono i documenti e si osserva cosa emerge».

Si adotta la prima. Un registro dei trattamenti è un *artefatto di conformità*: la sua affidabilità e la sua auditabilità non possono dipendere da una strutturazione inferita, potenzialmente allucinata e non riproducibile. Uno schema esplicito garantisce inoltre che il modello sia interrogabile in modo prevedibile dal blocco di confronto (B7) e mantenibile nel tempo. L'AI non viene esclusa, ma **circoscritta** a un ruolo di arricchimento su un singolo campo (§5.1.4); ciò è coerente con l'uso selettivo dell'AI già previsto per il blocco B1 nella Figura ??.

### 5.1.2 Il registro-tipo CNIL come schema di riferimento

Il contenuto obbligatorio del registro è fissato dall'art. 30 del Regolamento (UE) 2016/679 [?] e, per il contesto svizzero, dall'art. 12 della LPD [?]; i due elenchi sono ampiamente sovrapponibili. In assenza di una pluralità di modelli operativi consolidati, il riferimento pratico più diffuso è il registro-tipo pubblicato dalla *Commission Nationale de l'Informatique et des Libertés* (CNIL), l'autorità di controllo francese, derivato direttamente dall'art. 30 [?, ?]. Adottarlo come base evita di progettare uno schema dal principio e lega il modello ad una fonte ampiamente autorevole e condivisa.

Il modello CNIL è organizzato per *attività di trattamento*: una scheda per ciascun trattamento, con i campi seguenti.

- identificazione del trattamento (nome, date di creazione e aggiornamento, base giuridica);
- attori: titolare del trattamento, eventuali co-titolari, responsabile della protezione dei dati (DPO), responsabili del trattamento esterni (*processors*);

- finalità del trattamento;
- categorie di persone interessate;
- categorie di dati personali, con evidenziazione delle categorie particolari (dati sensibili);
- categorie di destinatari (interni, esterni, responsabili esterni);
- trasferimenti verso Paesi terzi (destinazione e garanzie);
- durate di conservazione;
- misure di sicurezza tecniche e organizzative.

### 5.1.3 Normalizzazione in un modello relazionale

La scheda CNIL è *denormalizzata* — un foglio piatto per trattamento. Il modello interno la normalizza attorno all'entità `ProcessingActivity`, già introdotta nel §5.2.4, con i suoi campi scalari (nome, finalità, base giuridica, titolare, DPO) e un insieme di entità collegate in relazione 1–N: `DataSubjectCategory`, `DataCategory`, `Recipient`, `ThirdCountryTransfer`, `Retention` (tipicamente per categoria di dato) e `SecurityMeasure`. Si aggiunge un'entità non prevista esplicitamente dalla scheda CNIL ma necessaria al sistema, `InformationSystem`, che collega ogni trattamento ai sistemi e ai repository in cui i dati risiedono.

Due collegamenti fanno del ROPA non un semplice archivio, ma il riferimento operativo del sistema.

1. `DataCategory` è messa in corrispondenza con il **catalogo delle categorie di PII** usato dal motore di rilevamento (blocco B4). Il ROPA dichiara così quali categorie un trattamento *dovrebbe* contenere; il blocco B4 rileva quelle *effettivamente* presenti nei documenti. Il confronto tra i due insiemi è ciò che alimenta la verifica di conformità (B7): da un lato le PII rilevate ma non dichiarate (*orfane*, cfr. §5.2.4), dall'altro le categorie dichiarate ma mai riscontrate.
2. `InformationSystem` lega il trattamento ai documenti da analizzare, indicando al sistema *dove* cercare e *che cosa* attendersi.

### 5.1.4 Ruolo circoscritto dell'AI: normalizzazione, non strutturazione

La struttura viene popolata in modo **deterministico**: poiché un ROPA compilato secondo il modello CNIL ha colonne note, l'ingestione dei campi strutturati è un'operazione di parsing, senza AI. L'unico punto che richiede interpretazione è il campo **categorie di dati**, che nei registri reali è spesso redatto in linguaggio naturale e in modo sbrigativo (ad esempio «dati anagrafici, coordinate bancarie, contatti»). Qui l'AI interviene **una tantum e a livello**

**di singolo campo**, per normalizzare ed espandere quel testo libero nelle categorie canoniche del catalogo di PII (ad esempio «coordinate bancarie» → `iban`; «dati anagrafici» → `person_name`, `date_of_birth`, `italian_id`). La mappatura proposta è sottoposta a **conferma del DPO** (*human-in-the-loop*) prima di essere fissata.

Questo confina l'AI a un compito circoscritto, verificabile e reversibile, coerente con la strategia di uso selettivo dell'AI adottata altrove nel sistema, senza cedere alla strutturazione agentica dell'intero documento.

### 5.1.5 Punti aperti di progettazione

Come per la persistenza, alcune decisioni restano aperte e si riportano come lavoro in corso.

**5.1.5.0.1 Granularità della corrispondenza categorie–PII.** Va fissato se una categoria di dati del ROPA mappi su un singolo `pii_type` o su un insieme: nella pratica una voce sbrigativa («dati anagrafici») corrisponde quasi sempre a più categorie canoniche, il che suggerisce una relazione 1–N da formalizzare.

**5.1.5.0.2 Allineamento nLPD–GDPR.** Il modello parte dai campi CNIL (impianto GDPR); vanno annotate le differenze rilevanti dell'art. 12 LPD, in particolare le soglie e le eccezioni previste per le piccole e medie imprese, che incidono su quali trattamenti debbano comparire nel registro.

**5.1.5.0.3 ROPA non strutturato.** Il modello assume un registro già compilato in forma tabellare. Il caso di un ROPA fornito come testo libero (non nel formato CNIL) richiederebbe un passo di strutturazione più invasivo: va deciso se supportarlo e in che misura, restando entro il vincolo di non delegare all'AI la strutturazione complessiva.

## 5.2 Persistenza del registro delle PII

Il blocco B5 della Figura 5.3 — il registro delle PII rilevate — non è un semplice contenitore dell'ultimo stato osservato, ma l'elemento su cui poggia la capacità del sistema di ragionare sull'evoluzione dei dati personali nel tempo. La scelta del modello di persistenza che lo sostiene non è quindi un dettaglio realizzativo, ma una decisione architetturale che condiziona quali domande il sistema è in grado di rispondere. Questa sezione formalizza il requisito che la persistenza deve soddisfare, confronta gli approcci valutati e motiva quello adottato.

Un vincolo di progetto attraversa tutta la discussione: **il registro non conserva i valori effettivi delle PII**, ma solo riferimenti a esse (tipo, posizione, documento di appartenenza). È una scelta di minimizzazione del dato — un registro di conformità non deve a sua volta trasformarsi in un archivio di dati personali — e ha una conseguenza diretta sul significato che possono assumere gli eventi di «modifica» (cfr. §5.2.5).

### 5.2.1 Il requisito di tracciamento temporale

Le linee guida di progetto richiedono che il sistema mantenga una traccia tale per cui, se un utente in seguito modifica un file, sia possibile accorgersi che una determinata PII è stata cancellata o modificata rispetto a una rilevazione precedente. Il registro deve cioè poter rispondere non solo alla domanda «quali PII sono presenti ora?», ma anche «*che cosa è cambiato* rispetto alla scansione precedente?».

Questo è un requisito di **tracciamento temporale** e ha una conseguenza diretta sul modello dati: non basta uno stato corrente scollegato dal passato, serve un meccanismo che leghi esplicitamente le rilevazioni successive dello stesso documento. È il criterio rispetto al quale vengono valutate le opzioni che seguono.

### 5.2.2 Approcci valutati

Il problema non si riduce a una scelta binaria tra snapshot ed event logger: esistono tre approcci distinti, con profili di complessità e garanzie molto diversi, riassunti nella Tabella 5.1.

Tabella 5.1: Approcci valutati per la persistenza del registro delle PII.

| # | Approccio                      | Idea di fondo                                                              | Fonte di verità                       |
|---|--------------------------------|----------------------------------------------------------------------------|---------------------------------------|
| A | Snapshot completi              | Ogni scansione salva l'intero stato rilevato, indipendente dalle altre     | Ultimo snapshot                       |
| B | Event sourcing puro            | Si salvano solo gli eventi; lo stato corrente è <i>derivato</i> col replay | Il log degli eventi                   |
| C | Changelog ibrido (delta-based) | Stato corrente mutabile e log append-only secondario delle variazioni      | Lo stato corrente (log complementare) |

#### 5.2.2.1 Opzione A — Snapshot completi

A ogni esecuzione della pipeline si salva un'istantanea completa di tutte le PII rilevate (`pii_type`, `document_path`, `position`, `associated_processing`, `scan_date`) autoconsistente e indipendente dalle altre. Il modello dati è minimale (una sola entità, nessuna logica di correlazione), non esiste rischio di derivare uno stato errato perché ogni snapshot è lo stato, e la realizzazione è immediata.

Il limite è però esattamente sul requisito del §5.2.1: non esiste **alcuna relazione esplicita tra scansioni consecutive**. Con due snapshot presi a distanza di ore, ricostruire «che cosa è cambiato» richiede un confronto (diff) calcolato a posteriori, riga per riga, senza alcuna struttura che leghi le due fotografie. A ciò si aggiunge la ridondanza dei dati (le PII invariate vengono riscritte a ogni scansione) e il fatto che il tracciamento temporale non è una proprietà del modello ma un'operazione applicativa da implementare comunque. L'opzione non è scartata perché errata, ma perché sposta interamente sul livello applicativo il lavoro di correlazione che il requisito richiede, senza offrire una struttura dati che lo supporti.

#### 5.2.2.2 Opzione B — Event sourcing puro

Lo stato dell'applicazione non viene mai salvato direttamente: si registra ogni cambiamento come evento immutabile in un log append-only, e lo stato corrente si ottiene *rigiocando*

(replay) l'intera sequenza di eventi. Nella formulazione originale di Fowler, il log diventa la fonte di verità principale e lo stato è puramente derivato [?]. Il pattern offre per costruzione una storia completa e immutabile — si può ricostruire lo stato a qualsiasi istante passato — con auditabilità nativa, proprietà interessante per un sistema di conformità; qui il tracciamento temporale non è un'aggiunta, ma il modello stesso.

Su questo approccio la letteratura è però netta. Lo studio empirico di Overeem et al., basato su interviste con 25 ingegneri che hanno adottato il pattern in sistemi reali, identifica cinque sfide ricorrenti, tra cui una curva di apprendimento ripida e l'evoluzione dello schema (*schema evolution*): non difficoltà percepite, ma *liabilities* documentate del pattern [48]. Inoltre, poiché lo stato corrente non è memorizzato ma va ricostruito, anche l'interrogazione più semplice («quali PII ci sono ora in questo documento?») richiede di rigiocare gli eventi; per rendere efficienti le letture, l'event sourcing viene quasi sempre affiancato al pattern CQRS (*Command Query Responsibility Segregation*), che introduce un *secondo* modello di lettura mantenuto in parallelo, cioè ulteriore complessità architetturale [49, ?, ?]. A questo si sommano la crescita illimitata del log e la gestione di proiezioni, versioning degli eventi e consistenza eventuale. La stessa documentazione di riferimento raccomanda di adottare il pattern **solo** quando i benefici di auditabilità e ricostruzione storica giustificano la complessità introdotta, notando che per la maggior parte dei sistemi la gestione dati tradizionale è sufficiente [?].

### 5.2.2.3 Opzione C — Changelog ibrido delta-based

L'approccio adottato mantiene **due** strutture complementari:

1. uno **stato corrente mutabile** — la lista delle PII attualmente presenti, interrogabile direttamente senza alcuna ricostruzione;
2. un **log append-only delle variazioni** (*changelog*), *secondario*, che registra ogni delta tra una scansione e la successiva e lega esplicitamente ogni variazione alla scansione precedente dello stesso documento.

La differenza cruciale rispetto all'opzione B è che il log **non è l'unica fonte di verità**: lo stato corrente esiste già come dato di prima classe, quindi nessun replay è necessario per le operazioni quotidiane. Il changelog serve a rispondere alla domanda «che cosa è cambiato», non a ricostruire lo stato. L'approccio combina due concetti presenti in letteratura: il **dataset delta-driven** proprio del *Change Data Capture* (CDC), che cattura le variazioni tra uno stato e il successivo *senza* fare del log la fonte di verità esclusiva, mantenendo lo stato corrente come dato normale e interrogabile [?] !!!!!!!; e l'idea di **log immutabile append-only** come traccia di audit, mutuata dall'event sourcing ma applicata in forma non esclusiva.

*Nota terminologica.* Il CDC descritto da Kleppmann cattura i cambiamenti leggendo il *transaction log* di un database sorgente. Nel sistema qui proposto, invece, i cambiamenti vengono *rilevati* confrontando i risultati di scansioni successive

di documenti esterni: non esiste un database sorgente di cui intercettare le transazioni. Il modello è dunque *ispirato* al paradigma delta-based del CDC, non un'implementazione di CDC in senso stretto.

### 5.2.3 Motivazione della scelta

La scelta dell'opzione C è il risultato di un confronto esplicito di *trade-off*, sintetizzato nella Tabella 5.2, e si articola in quattro punti:

1. **Risolve il difetto di A.** Il changelog lega ogni variazione alla scansione precedente dello stesso documento: le scansioni non sono più fotografie isolate e la domanda «che cosa è cambiato» ha una risposta strutturale, non un diff calcolato a posteriori.
2. **Evita il costo di B.** Lo stato corrente è memorizzato e interrogabile direttamente: niente replay, niente proiezioni, niente CQRS, niente consistenza eventuale da gestire. Le sfide di adozione documentate da Overeem et al. [48] non si applicano, perché non si sta adottando event sourcing puro.
3. **Conserva l'auditabilità dove serve.** Se in futuro servisse la ricostruzione storica completa, resta possibile rigiocando il changelog — ma è una *possibilità*, non un requisito per il funzionamento quotidiano: si ottiene gran parte del beneficio di B senza pagarne il prezzo in anticipo.
4. **È coerente con la minimizzazione del dato.** Registrando solo riferimenti e non valori, sia lo stato corrente sia il changelog restano leggeri e privi di PII effettive.

Tabella 5.2: Sintesi comparativa dei tre approcci di persistenza.

| Criterio                             | A — Snapshot | B — Event sourcing | C — Changelog ibrido   |
|--------------------------------------|--------------|--------------------|------------------------|
| Relazione esplicita tra scansioni    | ✗            | ✓                  | ✓                      |
| Interrogazione stato corrente        | immediata    | replay / CQRS      | immediata              |
| Complessità realizzativa             | bassa        | alta               | medio-bassa            |
| Auditabilità / storia completa       | ✗            | ✓                  | parziale (estendibile) |
| Ridondanza dei dati                  | alta         | nessuna            | bassa                  |
| Coerenza con minimizzazione del dato | ✓            | ✓                  | ✓                      |
| Rischio di stato derivato errato     | nullo        | presente           | nullo                  |
| Sfide di adozione documentate        | —            | 5 [48]             | non applicabili        |

### 5.2.4 Modello dati concettuale

Il modello che segue è *technology-agnostic*: la scelta della tecnologia di persistenza concreta è discussa nel Capitolo 6. Oltre alle entità già definite nel modello (Document, Scan, ProcessingActivity), la persistenza introduce due entità principali.

PIIInstance rappresenta lo stato corrente, mutabile: «questa PII, in questo documento, così com'è ora». Comprende un identificatore, il pii\_type, il riferimento al Document, la

`current_position`, un riferimento opzionale (0..1) al `ProcessingActivity` — assente se la PII è *orfana*, cioè non riconducibile ad alcun trattamento dichiarato — e il riferimento all'ultima `Scan` che l'ha osservata. È la tabella che il report per il DPO legge **direttamente**. `PIIChange` è il log append-only, secondario, e rappresenta «che cosa è successo a un'istanza tra una scansione e l'altra». Comprende un identificatore, il riferimento all'`PIIInstance`, il `change_type` (vocabolario chiuso, cfr. §5.2.5), il riferimento alla `Scan` che ha prodotto la variazione, il riferimento alla `previous_scan` per lo stesso documento — ciò che lega le rilevazioni nel tempo — e un `timestamp`.

Le relazioni tra le entità sono: `Document` (1)–(N) `PIIInstance` (*contiene*); `PIIInstance` (1)–(N) `PIIChange` (*ha storia*); `Scan` (1)–(N) `PIIChange` (*genera*); `PIIInstance` (N)–(0..1) `ProcessingActivity` (*corrisponde a*, con 0 = *orfana*).

## 5.2.5 Punti aperti di progettazione

Alcune decisioni sul modello restano deliberatamente aperte: vanno risolte prima di bloccarlo definitivamente e ciascuna ha un impatto concreto. Si riportano qui come lavoro in corso.

**5.2.5.0.1 Registrazione della «scomparsa» di una PII: esplicita o implicita?** Quando una scansione non ritrova più un'istanza confermata in precedenza, sono possibili due strategie. Nella modalità **esplicita** il sistema scrive attivamente una `PIIChange` di tipo `REMOVED`: è più corretta per un log autoesplicativo (l'assenza di un dato non dovrebbe richiedere conoscenza esterna per essere interpretata), ma impone a ogni scansione un confronto attivo con lo stato precedente del documento. Nella modalità **implicita** non si registra alcun evento di rimozione e lo stato «rimossa» si deduce confrontando l'ultima variazione dell'istanza con la data dell'ultima scansione del documento: più semplice, ma il changelog da solo non basta a spiegare l'accaduto. L'ipotesi preferita è quella esplicita, più solida e compatibile con l'opzione C (il confronto attivo fa comunque parte del meccanismo di rilevazione dei delta).

**5.2.5.0.2 Significato dell'evento «modifica».** Poiché il registro non salva i valori effettivi delle PII, un evento di «modifica» non può riferirsi al cambiamento del *contenuto* della PII, mai memorizzato. Può riferirsi solo al cambio di **posizione** nel documento (evento `MOVED`) o a una **riclassificazione** del tipo. L'ipotesi di lavoro è quindi di non prevedere un generico evento `MODIFIED`, ma di scomporlo in variazioni dal significato preciso.

**5.2.5.0.3 Vocabolario chiuso dei tipi di variazione.** Si propone di formalizzare `change_type` come enumerazione chiusa: `NEW` (istanza rilevata per la prima volta), `CONFIRMED` (istanza già nota, ritrovata invariata), `MOVED` (istanza già nota, ritrovata in posizione diversa) e `REMOVED` (istanza già nota, non più presente — dipende dalla scelta sulla scomparsa). Un insieme

chiuso elimina ambiguità nel modello e nel diagramma; resta da confermare se questo set è completo per tutti i casi d'uso previsti.

**5.2.5.0.4 Ambito dello snapshot iniziale.** Anche in un modello delta-based serve un punto di partenza: la prima scansione di un documento non ha una «scansione precedente». Va deciso come rappresentare il *bootstrap* — l'ipotesi è di registrare tutte le istanze della prima scansione come NEW con `previous_scan` nullo. Ciò è coerente con quanto nota Kleppmann sul CDC, dove il processo parte comunque da uno snapshot iniziale che fa da riferimento per la successiva cattura dei delta [?]. !!!!!!!



## Capitolo 6

# Implementazione

### 6.1 Tecnologia di persistenza del registro PII

Il modello di persistenza del registro delle PII e la sua motivazione architeturale sono discussi nel §5.2: la scelta è ricaduta su un *changelog ibrido delta-based*, con uno stato corrente mutabile affiancato da un log append-only delle variazioni. Quel modello è *technology-agnostic*; resta da fissare la tecnologia concreta con cui realizzarlo.

La scelta è **deliberatamente rimandata** finché i requisiti non sono più stabili, per non vincolare l'implementazione a decisioni premature. I candidati principali sono due:

- una base dati **relazionale** (ad esempio SQLite), che offre *join* e interrogazioni relazionali «gratuite» ed è coerente con il vincolo di deployment locale in Docker senza servizi esterni;
- una persistenza **su file semi-strutturati** (JSON/JSONL), più leggera ma meno strutturata e priva di garanzie relazionali native.

La decisione va motivata quando il modello concettuale sarà bloccato — in particolare dopo aver risolto i punti aperti del §5.2.5 — e non prima, poiché la struttura definitiva delle entità e delle relazioni incide direttamente sui vantaggi relativi delle due opzioni.

### 6.2 Riutilizzo di un motore di detection esistente: valutazione di Microsoft Presidio

Come emerso dallo stato dell'arte (§3.8), Microsoft Presidio non risolve il problema di governance affrontato dal progetto; il suo *motore di rilevamento*, però, copre gran parte del livello regex e NER che il sistema deve comunque realizzare. Si valuta quindi se **costruire tale livello sopra Presidio** anziché scriverlo da zero. La decisione è **in corso** e sarà chiusa su base empirica; questa sezione ne fissa i termini.

Due modelli di integrazione sono possibili, con implicazioni opposte sull'architettura:

- usare l'*AnalyzerEngine* di Presidio come **orchestratore** dell'intera detection: massimizza il riuso, ma sostituirebbe la pipeline ibrida e la logica di merge proprietarie descritte nel Capitolo 5, che costituiscono il contributo del progetto;
- incapsulare Presidio **dietro il contratto** `PIIDetector` come un singolo detector che ne mappa i risultati in `PIICandidate`: la pipeline, il `MergeEngine` e il detector AI selettivo restano invariati, e Presidio diventa solo il fornitore di regex, checksum e NER.

Il secondo modello è preferito, perché preserva l'architettura e rende la scelta reversibile: l'astrazione `PIIDetector` consente di sostituire il fornitore senza toccare il resto del sistema. I criteri di valutazione sono:

- **copertura** delle categorie del catalogo: Presidio fornisce riconoscitori pre-costruiti per gran parte di esse (email, IBAN, carta di credito, indirizzo IP, codice fiscale italiano), diversi con **validazione a checksum** già inclusa — proprio ciò che il progetto aveva rimandato;
- **estensibilità** sugli identificatori mancanti: il numero AVS svizzero richiederebbe comunque un riconoscitore su misura, come nell'implementazione attuale;
- **integrazione del livello NER**: Presidio supporta ufficialmente modelli esterni, incluso GLiNER, coerente con la scelta zero-shot (§3.1.3);
- **vincoli di progetto**: esecuzione interamente on-premise e configurabilità da file, coerente con l'estensibilità config-driven richiesta.

**6.2.0.0.1 Profilo hardware.** Un ulteriore elemento a favore riguarda i requisiti di calcolo. Il motore di Presidio e il livello di rilevamento basato su spaCy operano interamente su **CPU**, senza richiedere una GPU dedicata; l'accelerazione a GPU è soltanto opzionale ed è riservata ai modelli NER più onerosi (transformers, GLiNER), verso i quali il sistema ripiega comunque in automatico sulla CPU qualora la GPU non sia presente. Questo profilo è coerente con il vincolo di esecuzione on-premise su infrastruttura di PMI, dove hardware accelerato è raramente disponibile, e costituisce quindi un rafforzamento del posizionamento del progetto più che una limitazione.

Restano in ogni caso a carico del progetto, indipendentemente dall'esito: il riconoscitore per il numero AVS, il `MergeEngine` con i livelli di conferma, il detector AI selettivo e l'intero blocco di gestione ROPA e verifica di conformità.

Il giudizio è affidato a una **misurazione diretta**: Presidio viene incapsulato come detector e valutato sullo stesso corpus annotato e con la stessa procedura di scoring (precision, recall, F1) impiegati per la baseline regex, così da confrontare i due approcci sullo stesso metro prima di decidere.

## **Capitolo 7**

# **Test e validazione**



## **Capitolo 8**

# **Risultati e discussione**



## **Capitolo 9**

# **Sviluppi futuri**





## Capitolo 10

# Studi effettuati

### 10.1 Uso AI in rapporto al suo impatto ambientale

Nella scelta della metodologia per la detection delle PII all'interno dei documenti, si è sollevato un problema non indifferente: che metodologia usare? I principali candidati (come espresso nella sezione [SEZIONE]) sono: rule-based, NLP / NER e generative AI. Come largamento approvato da innumerevoli studi, l'AI (specialmente usata in accoppiata con LLM) ottiene risultati praticamente perfetti, andando a scovare sfaccettature che alle altre metodologie sfuggono completamente. Specialmente, questa categorie di PII "perse per strada" sono quelle **legate al contesto, collegamenti multi-documenti e simili**.

Tuttavia, c'è un importante obiezione da tenere a mente: seppur la detection è sicuramente migliore usando LLM, il consumo energetico per il loro impiego è astronomicamente più alto rispetto ad utilizzare algoritmi deterministici o NER. [SEZIONE DI CONFRONTO CON NUMERI DA PAPER]

Alla luce di questi dati, è giusto fare un passo indietro e comprendere che...

### 10.2 Considerazioni su training

## Elenco delle figure

|     |                                                                       |    |
|-----|-----------------------------------------------------------------------|----|
| 5.1 | Pipeline di esecuzione del sistema . . . . .                          | 31 |
| 5.2 | Suddivisione in moduli dell'architettura . . . . .                    | 32 |
| 5.3 | Architettura a macro-blocchi del sistema (bozza) . . . . .            | 33 |
| 5.4 | Dettaglio del blocco B4: pipeline ibrida di rilevamento PII . . . . . | 34 |



# Elenco delle tabelle

3.1 Confronto empirico degli approcci di PII detection basato su evidenze dalla letteratura. . . . . 23

5.1 Approcci valutati per la persistenza del registro delle PII. . . . . 38

5.2 Sintesi comparativa dei tre approcci di persistenza. . . . . 40



# Bibliografia

- [1] Shirley Radack. Protecting Personally Identifiable Information.
- [2] Parlamento europeo e Consiglio dell'Unione europea. Regolamento (ue) 2016/679.
- [3] RS 235.1 - Legge federale del 25 settembre 2020 sulla protezione dei dati (LPD) | Fedlex.
- [4] IEEE-29148-SRS-LaTeX-Template/IEEE-29148-2018-SRS-Template.tex at main · wxnix/IEEE-29148-SRS-LaTeX-Template.
- [5] Sona College of Technology, India, Dhayanithi J, Marimuthu M, Sona College of Technology, India, Mohanraj G, Sona College of Technology, India, Neelashkumar P, and Sona College of Technology, India. A FRAMEWORK FOR ANALYSING UNSTRUCTURED DATA IN COMPUTING DEVICES. 12(1):2464–2468.
- [6] A. Makhambet and A. Moldagulova. A comparative analysis of machine learning methods for personal information recognition (PII) in unstructured texts. 3(1):41–52.
- [7] Harshit Rajgarhia, Suryam Gupta, Asif Shaik, Gulipalli Praveen Kumar, Y. Santhoshraj, Sanka Nithya Tanvy Nishitha, and Abhishek Mukherji. An Evaluation Study of Hybrid Methods for Multilingual PII Detection.
- [8] Nagaraju Velishetty. Personal Identifiable Information (PII) Detection and Identification for Fintech with AI and Text Analytics.
- [9] Warto, Supriadi Rustad, Guruh Fajar Shidik, Edi Noersasongko, Purwanto, Muljono, and De Rosal Ignatius Moses Setiadi. Systematic Literature Review on Named Entity Recognition: Approach, Method, and Application. 12(4):907–942.
- [10] Jianliang Yang, Xiya Zhang, Kai Liang, and Yuenan Liu. Exploring the Application of Large Language Models in Detecting and Protecting Personally Identifiable Information in Archival Data: A Comprehensive Study\*. In *2023 IEEE International Conference on Big Data (BigData)*, pages 2116–2123. IEEE.

- [11] Orlando Amaral, Muhammad Ilyas Azeem, Sallam Abualhaija, and Lionel C. Briand. NLP-based Automated Compliance Checking of Data Processing Agreements against GDPR.
- [12] Sinan Gultekin, Achille Globo, Andrea Zugarini, Marco Ernandes, and Leonardo Rigutini. An energy-based comparative analysis of common approaches to text classification in the Legal domain. In *AI, Machine Learning and Applications*, pages 31–41.
- [13] Johannes Zschache and Tilman Hartwig. Comparing energy consumption and accuracy in text classification inference. 16(1):12717.
- [14] Ian Goodfellow, Yoshua Bengio, and Aaron Courville. Deep Learning.
- [15] Jacob Devlin, Ming-Wei Chang, Kenton Lee, and Kristina Toutanova. BERT: Pre-training of Deep Bidirectional Transformers for Language Understanding. In Jill Burstein, Christy Doran, and Tamar Solorio, editors, *Proceedings of the 2019 Conference of the North American Chapter of the Association for Computational Linguistics: Human Language Technologies, Volume 1 (Long and Short Papers)*, pages 4171–4186. Association for Computational Linguistics.
- [16] Yongqin Xian, Christoph H. Lampert, Bernt Schiele, and Zeynep Akata. Zero-Shot Learning – A Comprehensive Evaluation of the Good, the Bad and the Ugly.
- [17] Tom B. Brown, Benjamin Mann, Nick Ryder, Melanie Subbiah, Jared Kaplan, Prafulla Dhariwal, Arvind Neelakantan, Pranav Shyam, Girish Sastry, Amanda Askell, Sandhini Agarwal, Ariel Herbert-Voss, Gretchen Krueger, Tom Henighan, Rewon Child, Aditya Ramesh, Daniel M. Ziegler, Jeffrey Wu, Clemens Winter, Christopher Hesse, Mark Chen, Eric Sigler, Mateusz Litwin, Scott Gray, Benjamin Chess, Jack Clark, Christopher Berner, Sam McCandlish, Alec Radford, Ilya Sutskever, and Dario Amodei. Language Models are Few-Shot Learners.
- [18] Pritesh Jha. PII-Bench: A Unified Multi-Source Benchmark Corpus for Personally Identifiable Information Detection.
- [19] Luca Mainetti and Andrea Elia. Detecting Personally Identifiable Information Through Natural Language Processing: A Step Forward.
- [20] Enterprise-Scale PII De-Identification with Microsoft Presidio Anonymizer: Architecture, Use Cases, and Best Practices.
- [21] Yanai Elazar, Akshita Bhagia, Ian Magnusson, Abhilasha Ravichander, Dustin Schwenk, Alane Suhr, Pete Walsh, Dirk Groeneveld, Luca Soldaini, Sameer Singh, Hanna Hajishirzi, Noah A. Smith, and Jesse Dodge. What's In My Big Data?

- [22] Minqi Jiang, João G. M. Araújo, Will Ellsworth, Sian Gooding, and Edward Grefenstette. Generative Data Refinement: Just Ask for Better Data.
- [23] Imed Keraghel, Stanislas Morbieu, and Mohamed Nadif. Recent Advances in Named Entity Recognition: A Comprehensive Survey and Comparative Study.
- [24] Noopur Zambare, Kiana Aghakasiri, Carissa Lin, Carrie Ye, J. Ross Mitchell, and Mohamed Abdalla. Towards Fair and Efficient De-identification: Quantifying the Efficiency and Generalizability of De-identification Approaches.
- [25] Ben. Best Open Source Models for PII Redaction.
- [26] Kushagra Mishra, Harsh Pagare, and Kanhaiya Sharma. A hybrid rule-based NLP and machine learning approach for PII detection and anonymization in financial documents. 15(1):22729.
- [27] Byamugisha Africano, Gideon Mpungu, Daudi Jjingo, and Ggaliwango Marvin. PII Detection in Low-Resource Languages Using Explainable Deep Learning Techniques. In *Proceedings of the 2024 Sixteenth International Conference on Contemporary Computing*, pages 94–103. ACM.
- [28] Urchade Zaratiana, Ash Lewis, and George Hurn-Maloney. GLiNER2-PII: A Multilingual Model for Personally Identifiable Information Extraction.
- [29] Comparing Best NER Models For PII Identification.
- [30] Knowledgator/gliner-pii-base-v1.0 · Hugging Face.
- [31] Open Source PHI De-Identification: A Technical Review.
- [32] Andres Felipe Zambrano, Shreya Singhal, Maciej Pankiewicz, Ryan Shaun Baker, Chelsea Porter, and Xiner Liu. De-identifying student personally identifying information in discussion forum posts with large language models. 126(5–6):401–424.
- [33] Alexandra Sasha Luccioni, Yacine Jernite, and Emma Strubell. Power Hungry Processing: Watts Driving the Cost of AI Deployment? In *The 2024 ACM Conference on Fairness Accountability and Transparency*, pages 85–99.
- [34] Hao Yu, Zachary Yang, Kellin Pelrine, Jean Francois Godbout, and Reihaneh Rabbany. Open, Closed, or Small Language Models for Text Classification?
- [35] Lokesh Koli, Shubham Kalra, and Karanpreet Singh. Decoding Complexity: Intelligent Pattern Exploration with CHPDA (Context Aware Hybrid Pattern Detection Algorithm).
- [36] Noora Al Qahtani. A Comparative Study of Supervised vs. Unsupervised Learning Techniques for Real-Time Intrusion Detection in Cybersecurity Networks.



- [37] Xichen Zhang, Amir David, Haruna Isah, and Hasan Cavusoglu. Personally identifiable information detection in smart edge computing: A robust model evaluation. 328:114153.
- [38] Microsoft Presidio.
- [39] Urchade Zaratiana, Nadi Tomeh, Pierre Holat, and Thierry Charnois. GLiNER: Generalist Model for Named Entity Recognition using Bidirectional Transformer.
- [40] Scrubadub.
- [41] Overview of Varonis AI-Powered Data Discovery and Classification.
- [42] Data Classification Buyer's Guide: How to Choose a Data Classification Solution.
- [43] Varonis Software Pricing & Plans 2025: See Your Cost.
- [44] BigID Data Sheet: GDPR Compliance.
- [45] Privacy Suite.
- [46] Detecting Personal Names in Texts: Technical Whitepaper.
- [47] PII Tools | Discover, analyze & remediate sensitive data anywhere.
- [48] Michiel Overeem, Marten Spoor, Slinger Jansen, and Sjaak Brinkkemper. An Empirical Characterization of Event Sourced Systems and Their Schema Evolution – Lessons from Industry. 178:110970.
- [49] Greg Young. CQRS Documents by Greg Young.